Documento de definición de arquitectura de integración bancaria

Modernización de sistemas bancarios

Autor David Leonel Toala Mosquera

Versión 1.0

Fecha 9 de noviembre de 2026

Índice

1. Contexto y objetivos 4
2. Alcance, restricciones y supuestos 4
3. Arquitectura objetivo y vistas C4 5
4. Principios, patrones y decisiones tecnológicas 9
5. Seguridad, cumplimiento y protección de datos 15
6. Disponibilidad, recuperación ante desastres y latencia 18
7. Coexistencia e integración multicore 21
8. Identidad y control de acceso 22
9. APIs internas, Open Finance y mensajería de eventos 23
10. Gobierno de APIs y microservicios 24
11. Migración gradual y transición operativa 25
12. Observabilidad y trazabilidad 28
13. Artefactos de arquitectura 30

Resumen ejecutivo

La propuesta incorpora un core digital en AWS para mejorar las funciones de Cuenta Bancaria y ofrecer Tarjeta de Crédito, Seguros e Inversiones. La migración abarca únicamente las cuentas y utiliza los contratos vigentes de los canales. La plataforma conecta Web y App de Personas y Empresas, Open Finance y Servicios de Pago con ambos cores y los sistemas de Riesgos y Fraude.

Akamai protege la entrada y Apigee hybrid publica las APIs. Empresas, Personas y Externos se despliegan por separado, cada carga con su clúster EKS, su base Aurora y su clúster MSK. El diseño API-led separa la adaptación al canal, la orquestación y el acceso a sistemas, con contratos BIAN donde corresponde. La posición consolidada de empresa consulta cuentas, tarjetas, inversiones y pólizas en paralelo y muestra los resultados disponibles ante una falla parcial.

En cada clúster EKS, Istio cifra las llamadas internas con mTLS y las autoriza por identidad de servicio. Dynatrace Operator configura la instrumentación para recoger métricas y trazas. Argo CD sincroniza desde Git los despliegues aprobados para cada namespace. Kyverno aplica políticas de admisión que exigen imágenes autorizadas y un mínimo de réplicas. CrowdStrike Falcon Operator gestiona el despliegue de la protección de las cargas y Falcon genera alertas sobre amenazas durante la ejecución.

Durante la coexistencia, el core tradicional atiende las cuentas pendientes de migrar. El digital atiende las migradas y las altas habilitadas. El catálogo temporal del tradicional identifica el core vigente por cuenta. La migración empieza con un piloto y avanza por lotes. En cada corte se pausan las escrituras y se concilian saldos y movimientos. Operación comprueba la primera escritura en el destino y valida el cierre contable antes de ampliar.

Un pago con resultado incierto queda «En verificación». El canal recibe una referencia para consultar el estado y Transacciones verifica el resultado en el core registrado antes de decidir si corresponde un reintento. El estado y el evento se guardan en una misma transacción de Aurora. El publicador envía el evento a MSK. Riesgos reconoce los duplicados y Operación reprocesa los mensajes fallidos tras corregir la causa.

El acceso se controla con autenticación fuerte y permisos por recurso. El cifrado protege los datos en tránsito y en reposo. En Open Finance, cada consulta comprueba el consentimiento vigente para el tercero, la cuenta y los datos solicitados. Para atender la LOPDP, el diseño prevé minimizar los datos y registrar su tratamiento. El alcance de PCI DSS se delimita por flujo.

El CMDB registra responsables, contratos y versiones desplegadas. Las pruebas de integración continua verifican los contratos de APIs y eventos antes de promover cambios. Las trazas de Dynatrace permiten seguir una solicitud desde el canal hasta el core y, cuando se publica un evento, hasta su consumidor. Operación recibe alertas por fallas y tiempos de respuesta fuera de objetivo.

En Web y App, el objetivo de latencia p95 es de hasta 500 ms para consultas y hasta 1 segundo para la respuesta inicial de una transacción. EKS Auto Mode ajusta la capacidad de cómputo para alojar las réplicas cuando los servicios escalan. Los flujos críticos tienen redundancia en tres zonas de Virginia y una reserva activa a capacidad reducida en Oregón, con el estado replicado. Los ensayos de conmutación y retorno deben comprobar un tiempo de recuperación de hasta 2 horas y una pérdida máxima de 5 minutos de estado operativo.

1. Contexto y objetivos

Objetivo

Diseñar la arquitectura de integración para modernizar la banca, migrar Cuenta Bancaria al core digital, ampliar la oferta de productos y atender los requisitos regulatorios.

Problemática de integración

El core tradicional gestiona Cuenta Bancaria. El banco adopta el digital por las mejoras en Cuenta Bancaria y la incorporación de Tarjeta de Crédito, Seguros e Inversiones. La transición exige integrar ambos cores con Web y App, Pagos, Open Finance, Riesgos y Fraude.

2. Alcance, restricciones y supuestos

Sistema de interés y límites

La **Plataforma de Integración Bancaria** gestiona las APIs, los adaptadores, el enrutamiento multicore y la mensajería. Cada sistema conserva sus datos y reglas de negocio. La migración abarca exclusivamente Cuenta Bancaria.

Onboarding coordina el alta digital con Facephi y el Registro Civil, sistemas externos de verificación. El CDP (Customer Data Platform) es un sistema interno de consulta de datos de clientes para el alta, la apertura de cuentas, las inversiones y la entrega de tarjetas. El banco administra Consentimientos como registro interno para Open Finance, tratamientos de datos personales y accesos empresariales que requieran consentimiento. Cada dominio define la finalidad y el alcance del consentimiento de su caso de uso.

Condicionantes y supuestos

Ecuador es la jurisdicción de referencia del diseño. El documento incluye vistas de contexto, contenedores y componentes del modelo C4. La sección C3 se enfoca en los microservicios de un namespace. Se aplica BIAN (Banking Industry Architecture Network) a los dominios pertinentes, con ejemplos de APIs y eventos. La analítica de negocio queda fuera del alcance.

Tabla 1 Supuestos y criterios de calidad

Aspecto	Supuesto adoptado para el caso
Despliegue	El core tradicional opera en el centro de datos del banco en Ecuador. El core digital y la plataforma de integración operan en AWS, con conectividad privada entre entornos.
Interfaces	El core tradicional expone SOAP. El core digital y los sistemas de pagos, riesgos y fraude exponen APIs REST.
Capacidades por core	El tradicional atiende las cuentas pendientes de migrar. El digital atiende cuentas migradas y nuevas altas habilitadas, además de Tarjeta de Crédito, Seguros e Inversiones.
Carga y latencia	Pico de 100 solicitudes por segundo. Desde Web y App, p95 de hasta 500 ms para consultas (saldos y movimientos) y hasta 1 segundo para la respuesta inicial de transacciones (transferencias y pagos), con referencia y estado.
Recuperación	Caída de Virginia. RTO de 2 h para flujos críticos y RPO de 5 min para su estado operativo. Core digital recuperable dentro del RTO del flujo.

3. Arquitectura objetivo y vistas C4

3.1 Visión de la arquitectura objetivo

La Plataforma de Integración Bancaria reúne tres sistemas para Empresas, Personas y Externos. Integra App, Web, Open Finance y servicios de pago con los sistemas del banco y permite incorporar canales y productos mientras conviven los cores tradicional y digital.

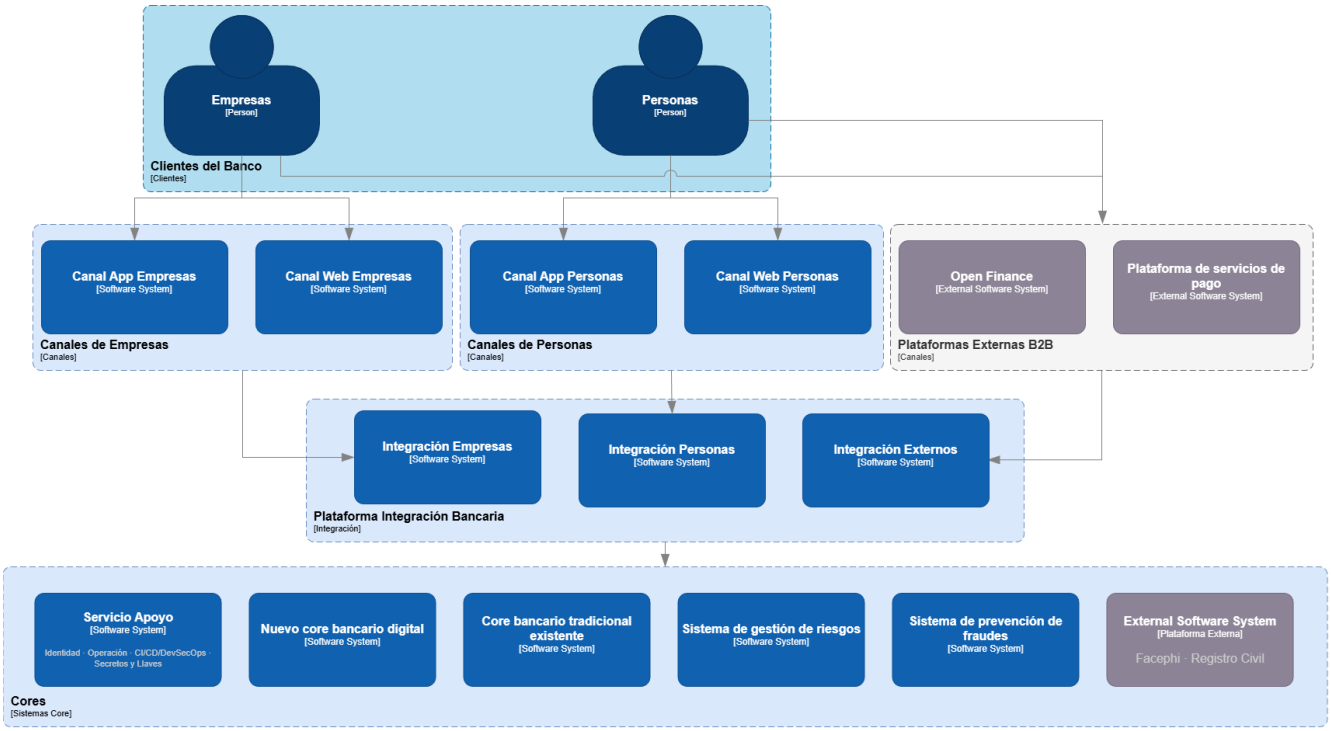
Cada carga usa EKS, Aurora y MSK propios y asigna un namespace a cada aplicación. Akamai protege la entrada y Apigee hybrid aplica las políticas de acceso. El patrón API-led separa experiencia, orquestación y acceso a sistemas, con contratos BIAN donde corresponde.

La Posición Consolidada de Empresa consulta cuentas, tarjetas, inversiones y pólizas en paralelo y presenta los resultados disponibles. Solo la rama de Cuenta Bancaria consulta el catálogo para elegir el core. Las demás usan rutas fijas al core digital.

3.2 Contexto general de la Plataforma de Integración Bancaria

La Figura 1 presenta el panorama de sistemas (System Landscape). Empresas y Personas usan sus canales App y Web y, según el servicio, las plataformas externas de Open Finance y pagos.

Figura 1 Panorama de sistemas de la Plataforma de Integración Bancaria



[System landscape] Plataforma de Integración Bancaria

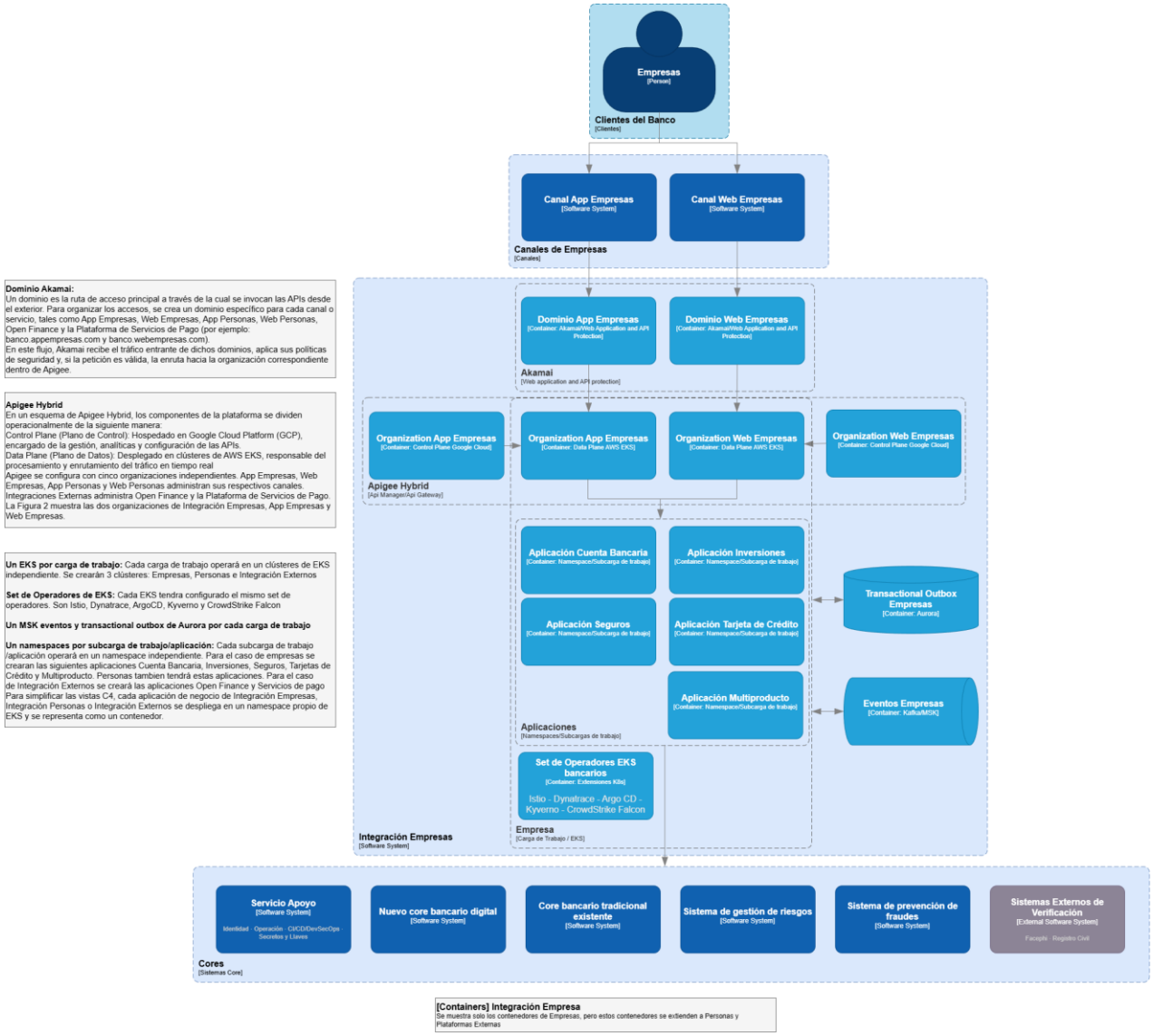
La plataforma agrupa tres sistemas. Integración Empresas recibe las solicitudes de los canales de Empresas, Integración Personas recibe las de Personas e Integración Externos conecta a Open Finance y a la plataforma de servicios de pago.

La banda inferior reúne las dependencias de la plataforma. Incluye el core tradicional existente, el nuevo core digital y los sistemas de gestión de riesgos y prevención de fraudes. Servicio Apoyo agrupa identidad, operación, CI/CD, DevSecOps, secretos y llaves. Facephi y Registro Civil figuran como sistemas externos de verificación.

3.3 Contenedores C2

La Figura 2 amplía Integración Empresas, uno de los sistemas identificados en la Figura 1, y muestra sus contenedores. Akamai protege los dominios de App y Web y envía a Apigee hybrid el tráfico admitido. Personas y los servicios B2B siguen el mismo patrón de entrada.

Figura 2 Contenedores de Integración Empresas



Google Cloud aloja el plano de control, que gestiona la configuración y la analítica de App Empresas y Web Empresas. El plano de datos comparte EKS Empresas con las aplicaciones. Aplica las políticas de acceso y dirige las solicitudes a la Experience API.

Cada carga tiene su propio clúster EKS, clúster MSK y base Aurora. Cada aplicación usa un namespace propio. Empresas y Personas incluyen Cuenta Bancaria, Inversiones, Seguros y Tarjeta de Crédito. Empresas incorpora Operaciones Multiproducto (3.5). Integración Externos separa Open Finance y Servicios de Pago.

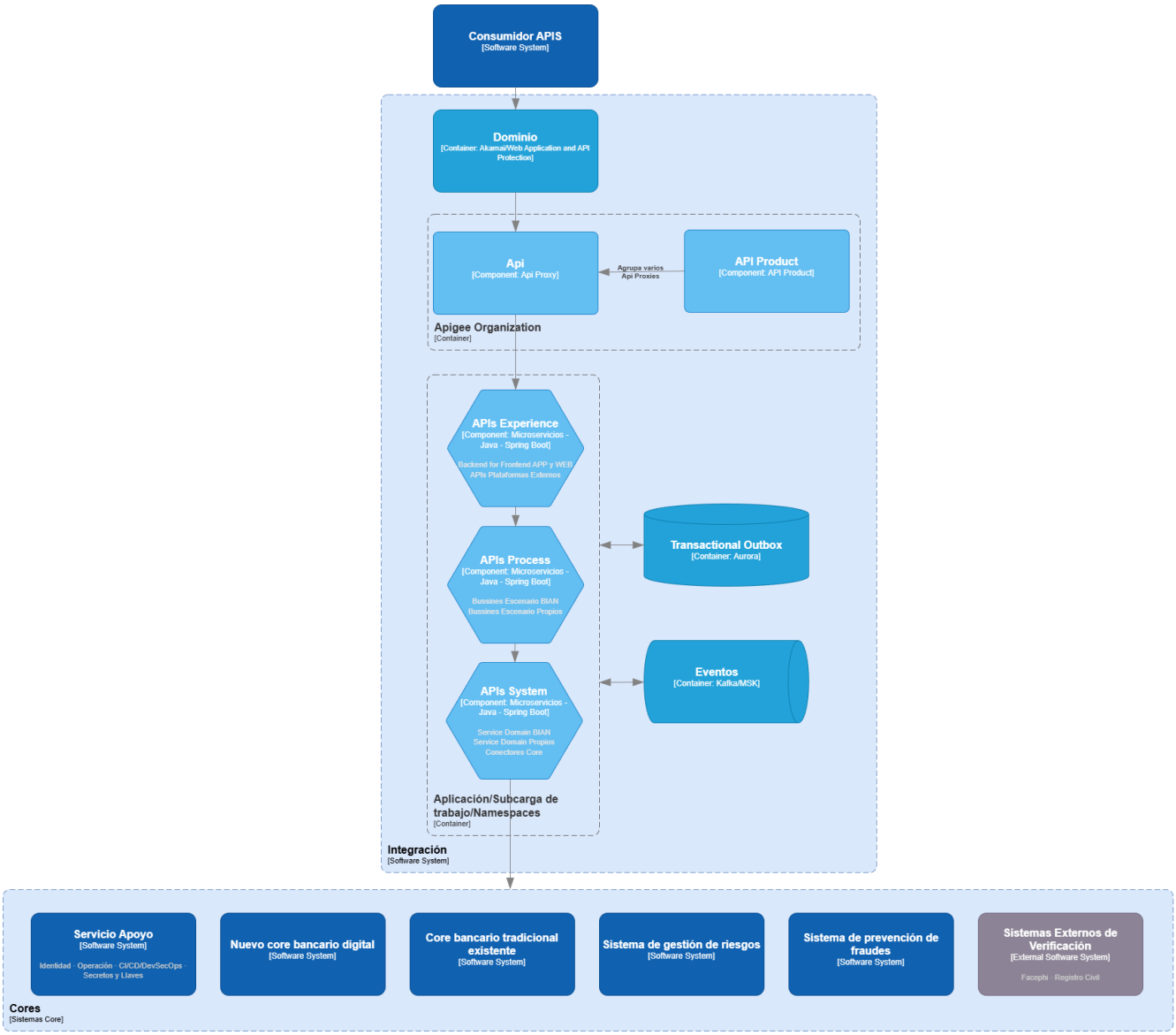
Cada clúster incorpora Istio, Dynatrace, Argo CD, Kyverno y CrowdStrike Falcon para operación y seguridad.

Transacciones guarda el estado y el evento en una misma transacción de Aurora, que también conserva la clave de idempotencia. El publicador lee el outbox y publica en MSK (secciones 7.2 y 9.2). Los conectores acceden a los cores y sistemas relacionados según la operación.

3.4 Componentes C3 · Vista combinada de referencia

La Figura 3A descompone dos contenedores, la organización de Apigee y la subcarga. El patrón API-led es común a Empresas, Personas y Externos, con entrada por Akamai.

Figura 3A Componentes API-led de una subcarga de integración



Cada API Product agrupa operaciones de uno o varios proxies dirigidas a un mismo namespace. El proxy aplica las políticas de acceso e invoca la Experience API de destino.

Las figuras 3A y 3B muestran los microservicios Java/Spring Boot como componentes lógicos por capa, incluso con despliegues propios, según la Figura 2. Las Experience APIs adaptan las solicitudes con BFF para App y Web y con APIs B2B para Open Finance y Servicios de Pago. Las Process APIs orquestan escenarios BIAN o propios. Las APIs de dominio exponen contratos BIAN o del banco. Los conectores System API adaptan el acceso a los cores y otros destinos.

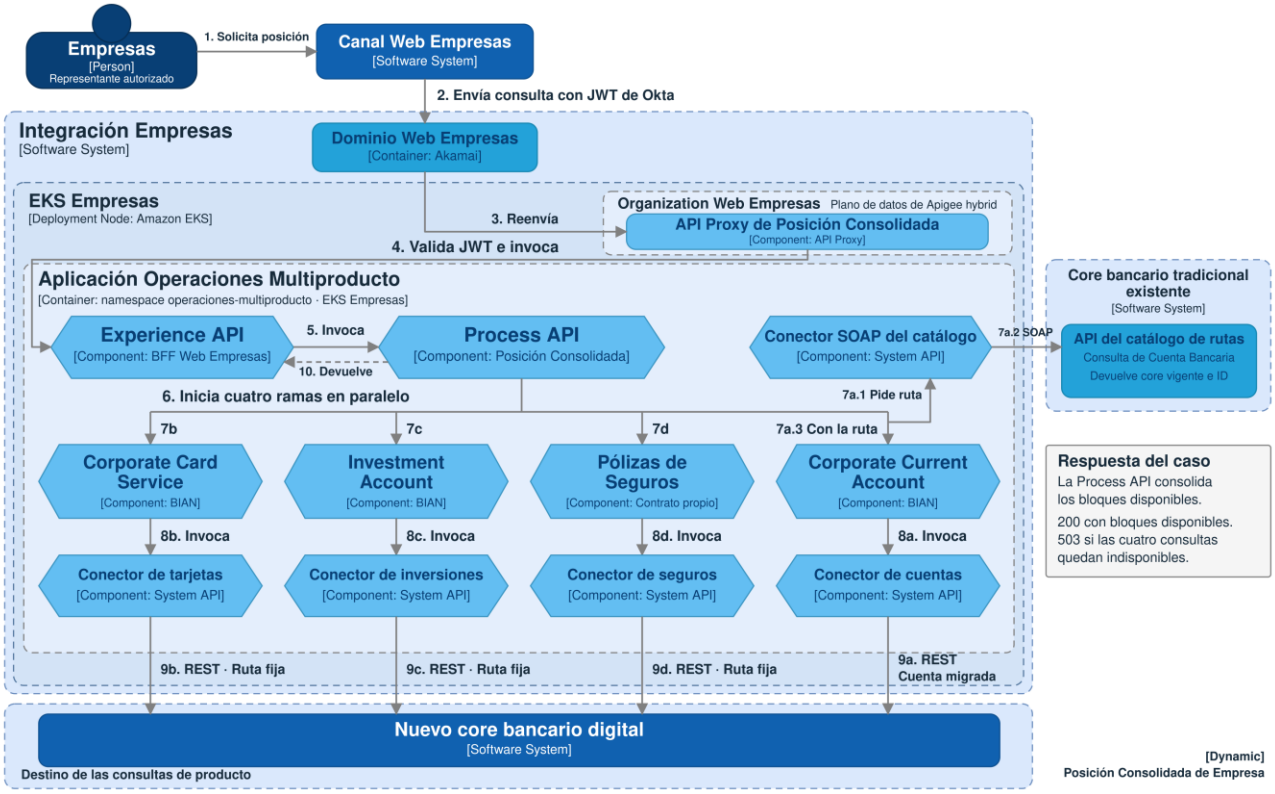
Transacciones registra el cambio de estado y su evento en una misma transacción de Aurora. El publicador lee el outbox y envía el evento a MSK para los consumidores autorizados (sección 9.2).

3.5 Caso de uso de Posición Consolidada de Empresa

El namespace operaciones-multiproducto de EKS Empresas aloja el BFF Web, la Process API y las APIs de dominio con conectores locales para escenarios que combinan productos.

Figura 3B Interacción de APIs para la posición consolidada de empresa

Diagrama dinámico C4



API de dominio	Información que aporta	Conector y core del ejemplo
Corporate Card Service	Tarjetas corporativas, saldo utilizado y cupo disponible.	Conector de tarjetas → core digital por REST.
Corporate Current Account	Cuentas corrientes y saldos disponibles.	Conector de cuentas → core digital por REST.
Investment Account	Instrumentos y valoración al último corte.	Conector de inversiones → core digital por REST.
Pólizas de Seguros (contrato propio)	Pólizas vigentes y coberturas.	Conector de seguros → core digital por REST.

La Process API valida permisos e inicia cuatro ramas en paralelo. En Cuenta Bancaria consulta el catálogo del core tradicional y elige el destino. La cuenta del ejemplo ya migró al core digital. Tarjetas, inversiones y pólizas se consultan en el digital por rutas fijas. El BFF presenta los bloques disponibles con fecha de corte y moneda cuando aplica.

Pólizas de Seguros usa un contrato propio. Los Deployments BIAN 14.0 declaran bian-service-domain. La etiqueta bian-business-scenario identifica escenarios publicados por BIAN. Corporate Card Service pertenece a Products / Cards y usa Corporate Card Master Account como Control Record.

4. Principios, patrones y decisiones tecnológicas

Principios de diseño aplicados

Cada aplicación se despliega en su propio namespace. El responsable de la subcarga controla su configuración, identidad, recursos y promoción de versiones. Cuenta Bancaria y Operaciones Multiproducto pueden reutilizar el mismo artefacto versionado del conector de cuentas. Argo CD despliega cada copia por separado, con permisos y pool de conexiones propios dentro de la cuota del core (3.3 y 7.1).

Tabla 2 Aplicación de principios de diseño

Principio y nivel	Atributo	Decisión aplicada	Verificación y referencia
Separación de responsabilidades (SoC) Arquitectura y componentes	Cohesión y funciones claras	Apigee aplica las políticas de acceso y el BFF adapta la solicitud. La Process API compone la posición y elige el core de la cuenta. Corporate Current Account expone el contrato BIAN y el conector adapta el protocolo del core seleccionado.	Trazar la consulta y comprobar qué componente cumple cada función. §3.4 · §3.5 · Fig. 3B
Responsabilidad única (SRP) Arquitectura y componentes	Cohesión y mantenibilidad	Transacciones coordina el pago y registra su estado. El adaptador entrega el evento a Riesgos, que realiza la evaluación.	Ante una falla definitiva de entrega, verificar el pago confirmado y el evento en la DLQ. §4.2 · §12.2
Abierto y cerrado (OCP) Componentes	Mantenibilidad y evolución independiente	El conector REST del core digital se incorpora con el contrato interno de consulta de cuentas. El catálogo registra el destino por cuenta.	Consultar una cuenta de prueba migrada al digital con el contrato vigente del canal. §7.1 · §11.2
Sustitución de Liskov (LSP) Componentes	Contratos explícitos y testabilidad	En la consulta de cuentas, los conectores SOAP y REST dan el mismo significado al saldo disponible, la moneda y los errores.	Probar saldo y cuenta inexistente en ambos conectores con datos equivalentes. §7.1 · §9.1
Segregación de interfaces (ISP) Arquitectura y componentes	Bajo acoplamiento y contratos explícitos	El contrato de saldos de Open Finance expone la consulta y los campos autorizados. Los pagos tienen su propio contrato.	Revisar los campos del contrato y comprobar el 403 por consentimiento revocado. §9.1 · Tabla 5
Inversión de dependencias (DIP) Componentes	Bajo acoplamiento y testabilidad	La lógica de cuentas usa una interfaz definida por el dominio. Los conectores la implementan y traducen SOAP o REST.	Simular saldo y timeout del conector. Ante el timeout, verificar el bloque de cuentas como no disponible. §3.5 · §7.1

Principio y nivel	Atributo	Decisión aplicada	Verificación y referencia
Zero Trust Arquitectura y componentes	Acceso verificable	Apigee valida el token, la Process API comprueba el permiso sobre la cuenta e Istio autoriza el salto interno por identidad.	Intentar consultar una cuenta ajena con un token válido y comprobar el rechazo. §5 · §8
Mínimo privilegio Arquitectura y componentes	Acceso limitado	Cada ServiceAccount recibe los permisos de su función. Cada conector usa un usuario exclusivo por subcarga y core.	Intentar una escritura con la credencial de un conector de consulta y comprobar el rechazo. §7 · §8 · Tabla 7
Denegación por defecto Arquitectura	Aislamiento	NetworkPolicy e Istio habilitan únicamente las rutas y llamadas autorizadas.	Comprobar el bloqueo de una llamada directa entre subcargas. §5.1 · §8.2
Defensa en profundidad Arquitectura	Protección por capas	Akamai filtra la entrada pública, Apigee aplica políticas de acceso y la Process API verifica el permiso sobre el recurso.	Probar el acceso directo al origen y el acceso a una cuenta fuera del alcance autorizado. §5 · Tabla 7
Minimización de datos Arquitectura y componentes	Privacidad	La consulta de tarjetas devuelve saldo, cupo y un token o PAN enmascarado. Los eventos incluyen los datos necesarios para su finalidad.	Revisar el contrato y una traza del flujo para verificar los campos expuestos. §5.2 · §9
Autonomía de subcargas Arquitectura	Evolución independiente	Cada subcarga controla la versión, la configuración y los recursos de sus despliegues. El conector reutilizado conserva identidad, permisos y pool propios por namespace.	Promover una versión del conector en Cuenta Bancaria y comprobar que Operaciones Multiproducto mantiene su versión. §3.3 · §7.1 · §10.2
Propiedad de datos y autoridad de escritura Arquitectura	Consistencia	El core vigente registra saldos y movimientos. Aurora se aprovisiona por carga. Transacciones escribe su estado, su clave de idempotencia y su outbox en el esquema que le pertenece. Otras aplicaciones consumen sus APIs o eventos autorizados.	Comprobar el rechazo de escrituras al esquema con otra identidad. Verificar la pausa y la autoridad del core durante un corte. §7 · §8.2 · §11 · Tabla 4
Evolución por contrato Arquitectura y componentes	Compatibilidad y testabilidad	Los cambios compatibles conservan la versión. Las versiones mayores conviven durante la transición.	Comprobar en CI la compatibilidad del contrato y el comportamiento del servicio. §9 · §10

Principio y nivel	Atributo	Decisión aplicada	Verificación y referencia
Degradación controlada Arquitectura y componentes	Continuidad y testabilidad	La posición consolidada entrega los bloques disponibles. Una escritura con resultado incierto queda En verificación.	Simular caída del catálogo con el digital operativo. Comprobar 200 con tres bloques y cuentas indisponibles. Simular timeout de escritura y comprobar el estado En verificación. §3.5 · §7.2 · Tabla 5 · Fig. 5A
Trazabilidad por diseño Arquitectura y componentes	Diagnóstico y auditoría	El ID de correlación enlaza la solicitud con la referencia del core. idOperacion e idEvento identifican el procesamiento en MSK.	Seguir una operación desde el canal hasta la entrega del evento o su alerta en la DLQ. §12 · Fig. 5A y 5B

Arquitecturas, patrones y prácticas aplicadas

Tabla 2A Arquitecturas, patrones y prácticas aplicadas

Tipo y nombre	Dónde se aplica	Motivo y manejo de fallos	Evidencia
Arquitectura Microservicios por subcarga	**Clúster por carga y namespace por aplicación.**	La separación acota el impacto de los fallos y permite liberar cada aplicación con su propia configuración, identidad y límites de recursos.	§3.3 Fig. 2 §4.1
Diseño de dominio DDD estratégico y BIAN 14.0	**Cuentas, Tarjetas, Inversiones y Seguros.**	Las capacidades delimitan responsabilidades y contratos. Las APIs de dominio aplican la semántica BIAN pertinente, como Corporate Current Account. Pólizas de Seguros usa contrato propio. El CMDB registra el Service Domain y el Business Scenario publicado cuando corresponden.	§3.5 §9.1 §10.1 Tabla 3
Arquitectura Clean Architecture	**Casos de uso de Cuentas y Transacciones.**	La aplicación define interfaces que implementan los conectores y repositorios. Así puede probar los casos de uso con dobles de prueba y sustituir el acceso al core sin cambiar el contrato de dominio.	§4.1 §7.1 §7.2
Arquitectura API-led y API Gateway	**Proxy de Apigee y APIs de cada subcarga.**	El proxy aplica políticas de acceso. App y Web usan BFF. Open Finance y Servicios de Pago usan Experience APIs B2B separadas, incluida la consulta de estado de pagos. Las capas de experiencia, proceso y sistema evolucionan según su responsabilidad.	§3.4 Fig. 3A §9.1 ADR 01
Arquitectura Despliegue híbrido	**Google Cloud, EKS y centro de datos del banco.**	El plano de control administra las APIs desde Google Cloud. El plano de datos procesa las solicitudes junto a las aplicaciones en EKS. La conectividad privada propuesta mantiene el acceso al core tradicional.	§3.3 Fig. 2 y 4 ADR 06

Tipo y nombre	Dónde se aplica	Motivo y manejo de fallos	Evidencia
Patrón Service mesh	**Llamadas internas de cada clúster.**	Istio aplica mTLS y autoriza por identidad de la carga. Las reglas limitan las llamadas al servicio y la operación requeridos.	§3.3 §5.1 §8.2
Patrón Composición y enrutamiento por autoridad	**Process API de Posición Consolidada.**	Las cuatro ramas inician en paralelo. Cuenta Bancaria espera el catálogo para elegir el core. Tarjetas, inversiones y pólizas siguen rutas fijas al digital. Si falla el catálogo con el digital operativo, la API devuelve 200 con los otros tres bloques y marca cuentas como indisponible. Si fallan los cuatro bloques, devuelve 503.	§3.5 Fig. 3B §7.2 Tabla 5
Patrón Adaptadores y capa anticorrupción	**System APIs de acceso a los cores.**	Los conectores traducen SOAP o REST y conservan el significado de los saldos, la moneda y los errores del contrato interno. El cambio de core queda aislado del contrato que consume el canal.	§3.4 §4.1 §7.1
Patrón Saga orquestada	**Transacciones en el pago con varios pasos.**	El orquestador conserva la referencia y coordina la reserva, el envío a Pagos y la confirmación. Fraude responde en línea cuando su decisión condiciona la operación. Un rechazo confirmado permite liberar la reserva.	Fig. 1 ADR 05 §7.2
Patrón Idempotencia y conciliación	**Comandos de Transacciones y core registrado.**	La clave permite reconocer comandos repetidos. Un timeout de escritura deja la operación En verificación. Transacciones consulta por referencia al core registrado y solo repite el comando cuando el core confirma un fallo transitorio sin aplicación y admite repetirlo.	§7.2 Fig. 5A §12.2
Arquitectura EDA, outbox y consumidor idempotente	**Transacciones, Aurora, MSK y adaptador de Riesgos.**	Registrar el estado y el evento juntos asegura que cada cambio confirmado tenga un evento pendiente de publicar. MSK permite a Riesgos evaluar de forma independiente del pago. El consumidor deduplica por idEvento, deriva fallos a la DLQ y conserva el identificador al reprocesar.	Fig. 1 §9.2 Fig. 5B ADR 04
Patrón Resiliencia síncrona	**Llamadas a cores y servicios relacionados.**	El timeout y el circuit breaker acotan el efecto de una dependencia indisponible. Los límites de concurrencia y pools por destino aíslan la capacidad (bulkhead). Se reintentan fallos transitorios con espera creciente cuando repetir la operación es seguro.	§6.1 §7.1 §7.2
Estrategia HA multizona y DR con warm standby	**Cargas críticas en Virginia y reserva en Oregón.**	La redundancia zonal limita interrupciones locales y la reserva regional permite recuperar flujos críticos. El runbook automatiza la conmutación y comprueba el estado antes de habilitar escrituras.	§6 Fig. 4
Estrategia Migración incremental	**Grupos de Cuenta Bancaria.**	El corte por grupos limita el impacto operativo. Migración pausa escrituras, concilia el grupo y cambia la autoridad solo después de verificar el estado en el destino.	§7.1 §11

Tipo y nombre	Dónde se aplica	Motivo y manejo de fallos	Evidencia
Práctica IaC, GitOps y promoción gradual	**Infraestructura regional y aplicaciones en EKS.**	IaC reproduce la infraestructura y Argo CD sincroniza versiones por namespace. El responsable verifica errores, latencia y réplicas listas en Dynatrace antes de ampliar el despliegue.	§6.2 §10.2 §12.2
Práctica Política como código y DevSecOps	**Pipeline de entrega y admisión en EKS.**	CI/CD ejecuta SAST, SCA y DAST. Kyverno verifica imágenes autorizadas, mínimos de réplicas y distribución para detectar incumplimientos antes del despliegue.	§5.1 §6.1 Tabla 7
Práctica Contratos versionados y pruebas en CI	**APIs HTTP y eventos de MSK.**	Las pruebas de compatibilidad protegen a los consumidores cuando evoluciona un contrato. El agente de IA señala diferencias. CI contrasta respuestas y eventos con los contratos y bloquea incumplimientos reproducibles.	§9 Tablas 5 y 6
Práctica Gobierno federado e inventario	**Equipos de dominio, subcargas y CMDB.**	El dueño de dominio responde por la capacidad y el contrato. El pipeline registra versiones, despliegues y dependencias para identificar a los consumidores afectados por un cambio.	§10 Tabla 3
Práctica Observabilidad y respuesta a incidentes	**Flujos desde el canal hasta los cores y consumidores.**	Dynatrace correlaciona métricas, registros y trazas para localizar el punto de fallo. El SIEM centraliza eventos de seguridad para el SOC y el CSIRT. La prueba sigue el pago hasta la alerta y el reproceso.	§5.1 §12 Fig. 5A y 5B
Práctica Vistas C4 y ADR	**Consumidores, contenedores, componentes y decisiones.**	Las vistas ubican los límites y las interacciones. Los ADR registran alternativas, motivos y consecuencias para revisar las decisiones cuando cambien sus supuestos.	§3 §13.7 Tabla 8

Tecnologías y justificación

Necesidad del diseño	Tecnología y justificación
Proteger el borde y publicar APIs	**Akamai App & API Protector protege la entrada pública. Apigee hybrid publica APIs por consumidor y aplica las políticas de acceso. En Empresas, el plano de datos comparte EKS con las aplicaciones para mantener el runtime junto a los servicios. Google Cloud aloja el plano de control (Fig. 2, §5.1 y ADR 01).**
Aislar ejecución y reutilizar conectores	**Amazon EKS Auto Mode ajusta la capacidad del clúster según la demanda. Los namespaces delimitan cada aplicación. Java y Spring Boot permiten reutilizar el artefacto de un conector con despliegues y configuraciones independientes (§3.3 y ADR 02).**
Integrar sistemas con contratos existentes	**SOAP/XML conserva el contrato del core tradicional y de su catálogo. REST/JSON se ajusta a las interfaces del core digital, Pagos, Riesgos y Fraude. Las System APIs adaptan esos contratos a la semántica interna (§3.4 y §7.1).**
Verificar contratos y compatibilidad	**OpenAPI describe los contratos HTTP y permite probar sus respuestas y errores. AsyncAPI documenta tópicos y mensajes. Protobuf define esquemas de eventos que CI verifica al evolucionar los contratos. Las versiones y la validación en Apigee se detallan en el §9.**
Distribuir eventos y guardar estado	**Kafka en Amazon MSK desacopla productores y consumidores, ordena los eventos por operación y permite releerlos. Aurora PostgreSQL guarda de forma atómica el estado de Transacciones, la idempotencia y el outbox (§7.2, §9.2 y ADR 04).**
Autorizar llamadas internas y diagnosticar fallos	**Istio aplica mTLS y autorización por identidad dentro de EKS. Dynatrace Operator habilita instrumentación para localizar latencia y fallos mediante métricas y trazas (§5.1 y §12).**
Gobernar cambios y proteger las cargas	**Argo CD sincroniza los despliegues desde Git. Kyverno valida las políticas de admisión. CrowdStrike Falcon Operator gestiona el despliegue de la protección de cargas (§5.1 y §10).**
Proteger identidades, secretos y claves	**Okta autentica a los clientes y Entra ID al personal. TLS o mTLS protege cada salto según su límite de confianza. AWS Secrets Manager centraliza credenciales y KMS administra las claves de cifrado (§5 y §8).**
Conectar con el core tradicional · Propuesta	**El ADR 06 propone AWS Direct Connect como enlace privado principal y AWS Site-to-Site VPN con IPsec por una ruta independiente. El respaldo ofrece una vía al centro de datos ante una falla del enlace principal. La decisión considera costo, capacidad y pruebas de conmutación (Fig. 4).**
Modernizar y ampliar la oferta	**El core digital amplía la capacidad de Cuenta Bancaria e incorpora Tarjeta de Crédito, Seguros e Inversiones. Ambos cores coexisten durante la migración de cuentas (§7.1 y ADR 07).**

5. Seguridad, cumplimiento y protección de datos

Controles por límite de confianza

La plataforma aplica Zero Trust y mínimo privilegio. Cada salto se cifra y se autoriza según la identidad, la operación y el recurso, incluso cuando el tráfico viaja por una red privada.

Akamai App & API Protector protege las aplicaciones y APIs públicas frente a ataques, bots y DDoS de capa 7. Web y App usan HTTPS. Akamai valida el certificado de los terceros B2B mediante mTLS. El enlace a Apigee hybrid usa HTTPS autenticado y el origen admite tráfico únicamente del borde autorizado.

Okta autentica a los clientes de Web y App con dos factores. Las operaciones que lo requieren, como transferir a una cuenta no registrada, exigen autenticación reforzada con un factor de un solo uso asociado a la operación. Apigee valida el JWT, la sesión y el permiso de acceso. En la posición consolidada, la Process API verifica empresa y permiso por producto antes de consultar cada rama (Figura 3B). Entra ID autentica al personal de TI con MFA y PAM controla el acceso privilegiado (8).

Para B2B, Akamai descarta las cabeceras de certificado que envía el tercero y remite por el enlace autenticado los datos del certificado que verificó. Open Finance usa Authorization Code con PKCE y mTLS. Antes de publicar, IAM comprueba en el entorno objetivo que Okta emite tokens ligados al certificado. Apigee compara la huella con cnf.x5t#S256 y rechaza la solicitud si falta o difiere. La Process API comprueba el consentimiento vigente en cada consulta (8.2).

En Pagos B2B, Apigee valida el token de Client Credentials y su alcance de consulta. Comprueba que el cliente del token esté registrado para el certificado validado por Akamai. La Process API verifica que la referencia pertenezca a ese tercero antes de leer el estado (8.2 y Tabla 5).

El alcance de 2.1 complementa el panorama de la Figura 1 con CDP y Consentimientos como dependencias internas. Onboarding y los dominios autorizados consultan en CDP solo los datos necesarios para su finalidad. Consentimientos registra la evidencia aplicable. La Process API de Open Finance verifica allí titular, tercero, cuenta, alcance, vigencia y revocación.

En cada clúster, Istio aplica mTLS y autoriza las llamadas por identidad. NetworkPolicy deniega por defecto el tráfico de entrada y salida y habilita los flujos requeridos. En EKS Auto Mode, IaC habilita su aplicación en la configuración de VPC CNI y NodeClass. Cada servicio usa un ServiceAccount en su namespace. EKS Pod Identity, o IRSA cuando corresponda, asigna permisos de AWS a los servicios que los requieren. RBAC limita la administración y Pod Security Admission aplica el perfil restringido, con excepciones justificadas para componentes de plataforma.

Los conectores REST y SOAP privados validan la identidad del destino mediante HTTPS en las rutas del esquema propuesto en el ADR 06. Cada conector usa una credencial de mínimo privilegio por subcarga y destino. MSK y Aurora usan TLS y autenticación. MSK limita la publicación por tópico y el consumo por tópico y grupo. Aurora limita por usuario y esquema. Transacciones escribe su estado e idempotencia y registra el outbox en su esquema. El publicador tiene acceso acotado al outbox (4.1).

AWS KMS gestiona las llaves de cifrado en reposo para Aurora, MSK, volúmenes y respaldos. Secrets Manager protege las credenciales y coordina su rotación con el destino. Se audita el uso de llaves. Si un flujo justifica JWE además de TLS, el contrato identifica campos, emisor, receptor y rotación de llaves. El perfil propuesto usa A256GCM y RSA-OAEP-256. El WAAP revisa los campos visibles y el receptor autorizado valida los descifrados. La prueba rechaza contenido alterado.

El pipeline ejecuta SAST sobre código, SCA sobre dependencias y DAST en pruebas. Argo CD despliega artefactos aprobados y Kyverno controla la admisión de imágenes. CrowdStrike Falcon Operator gestiona la protección de las cargas y Falcon aporta las alertas de ejecución.

Falcon Next-Gen SIEM recibe eventos de seguridad de Akamai, identidad, PAM, Apigee, EKS, Istio, Falcon, microservicios, conectores, cores y almacenes. CloudTrail registra operaciones administrativas de AWS. La auditoría de Aurora usa los registros de la base y las decisiones de acceso se registran en Apigee y la Process API. LogScale Collector recoge archivos o syslog y los servicios administrados usan conectores de datos. Cada registro conserva fecha, origen, actor, acción y resultado. El ID de correlación enlaza el flujo cuando aplica. Se excluyen credenciales, tokens y cuerpos y se enmascaran datos sensibles. Dynatrace analiza la telemetría operativa (12).

El SOC revisa alertas como denegaciones repetidas sobre cuentas ajenas. El CSIRT interno coordina contención y recuperación. Ante una brecha de datos, el banco registra cuándo tuvo constancia, evalúa el riesgo con el Delegado de Protección de Datos y conserva la decisión y los acuses. El encargado avisa al banco sin demora, en el término máximo de dos días desde que conoce la brecha. Cuando procede, el banco avisa a la SPDP por su canal oficial, al organismo de control competente y al CSIRT correspondiente. Lo hace sin demora y en el término máximo de cinco días desde que tuvo constancia. Cuando corresponde, avisa al titular sin demora y en el término de tres días desde que conoció el riesgo. Aplica los arts. 43 y 46 de la LOPDP y la Resolución SPDP-SPD-2026-0040-R.

Cumplimiento y protección de datos personales

El banco registra cada tratamiento conforme a la LOPDP y su Reglamento General. Documenta finalidad, base de legitimación, datos mínimos, accesos y conservación. Consentimientos guarda la evidencia cuando esa es la base aplicable. El Delegado de Protección de Datos asesora y supervisa la evaluación de impacto, la atención de derechos y la respuesta a brechas.

Datos y finalidad	Control aplicado	Evidencia
Identificación, cuentas y movimientos para banca y pagos	Acceso por cliente, empresa y recurso. Base contractual u obligación legal según la finalidad. Conservación definida por tratamiento.	Registro de tratamientos, prueba de acceso y evidencia de eliminación.
Cédula y biometría facial para alta digital	El banco acredita la necesidad de la biometría y completa la evaluación de impacto antes de habilitarla. La evaluación se revisa cada doce meses y si cambia el riesgo. El consentimiento es previo, libre, específico, informado, inequívoco y explícito. El alta ofrece una vía documental. Facephi procesa las imágenes necesarias para la verificación. El contrato delimita la retención y eliminación de capturas y plantillas. Onboarding conserva resultado y referencia. Consentimientos registra la aceptación.	Evaluación de impacto y revisión. Prueba de alta documental. Evidencia del consentimiento y del borrado por el proveedor. Resolución SPDP-SPD-2026-0039-R.
Datos para gestión de riesgos	El adaptador consume el evento autorizado de MSK y entrega por REST a Riesgos la referencia y las variables necesarias para su evaluación. Se registra la base aplicable y se evalúa el impacto si el tratamiento presenta alto riesgo.	Esquema del evento, revisión de campos y evaluación cuando aplica (4.2 y 9.2).

Datos y finalidad	Control aplicado	Evidencia
Datos para prevención de fraude	Fraude recibe por REST la referencia y las variables necesarias para la decisión en línea que condiciona la operación. Se registra la base aplicable y se evalúa el impacto si el tratamiento presenta alto riesgo.	Contrato REST, prueba de campos autorizados y evaluación cuando aplica (4.2).
Datos compartidos con terceros de Open Finance	Consentimiento por tercero, cuenta y finalidad, con vigencia y revocación verificadas en cada consulta.	Registro en Consentimientos y prueba de rechazo tras revocación.
Tarjetas en la posición consolidada	Para la Figura 3B, el core digital entrega saldo, cupo y el identificador necesario para mostrar la tarjeta, como sus últimos cuatro dígitos. El conector recibe el dato reducido. Esta consulta excluye PAN completo, CVV, PIN y datos de banda de la respuesta, los registros y el almacenamiento.	Pruebas del contrato y las trazas. Inventario PCI DSS y prueba de segmentación.
Copias temporales de Cuenta Bancaria para migración	Migración cifra las exportaciones en tránsito y reposo, limita el acceso por lote y ventana, y elimina temporales después de conciliar según la política de conservación.	Bitácora de accesos y conciliación, prueba de borrado (11).

El banco verifica la identidad de quien solicita acceso o rectificación y registra la fecha, el responsable y la respuesta dentro del plazo aplicable. Para una cuenta en migración, ubica el dato en el core vigente según el catálogo. Si el dato corresponde al CDP o a un encargado, tramita la solicitud con su responsable. Aplica la conservación por tratamiento y documenta la eliminación o el motivo legal de retención (7.1 y Tabla 4).

El banco clasifica cada acceso externo por el rol contractual del receptor. El registro cubre las regiones de AWS y los servicios externos que traten datos personales. Por flujo identifica datos, finalidad, ubicación y subencargados. Si el proveedor actúa por instrucciones del banco, documenta el encargo, la seguridad y la devolución o eliminación. Para comunicaciones a terceros, registra la base aplicable y, si son internacionales, el mecanismo habilitante y las cláusulas tipo cuando correspondan. Aplica la Resolución SPDP-SPD-2026-0004-R.

Para los servicios de nube, el banco identifica los procesos críticos y prepara los informes técnico, de seguridad y legal. Verifica que el alcance de ISO 27001 y de los controles ISO 27017 e ISO 27018 o equivalentes corresponda al servicio. Para los centros de datos contratados revisa el estándar ANSI-TIA-942 o superior y la certificación TIER III o equivalente. Revisa la evidencia de continuidad e informa a la Superintendencia de Bancos sobre los servicios asociados a procesos críticos a contratar. La Norma de Control para la Gestión del Riesgo Operativo sustenta estos controles y los de banca Web y App (arts. 23, 30 y 31). El alcance PCI DSS se delimita por flujo e incluye los componentes que procesan, almacenan o transmiten datos de tarjeta y los que pueden afectar la seguridad de ese entorno. La segmentación se comprueba con pruebas.

Evidencia en Tabla 7.

6. Disponibilidad, recuperación ante desastres y latencia

Alta disponibilidad y rendimiento

En Virginia, los servicios con perfil de alta disponibilidad se distribuyen en **tres zonas de disponibilidad**. Cada microservicio crítico sin estado mantiene **tres réplicas**, distribuidas por zona y nodo. El balanceador envía tráfico a las réplicas listas. Las sondas de readiness retiran las que dejan de estar disponibles y **PodDisruptionBudget** protege el mínimo durante mantenimientos voluntarios. Apigee, Aurora y MSK se despliegan con redundancia zonal.

El **HPA** escala los pods entre el mínimo y el máximo de cada servicio. **EKS Auto Mode** ajusta la capacidad de cómputo para alojarlos. El máximo se dimensiona con pruebas de carga y con la cuota de conexiones que el core asigna a cada conector. **Kyverno** valida en admisión el mínimo y las reglas de distribución. **Dynatrace** alerta por réplicas listas bajo el mínimo, pods pendientes o saturación al alcanzar el máximo.

Si se pierde una zona, el balanceador usa las réplicas sanas. La posición consolidada devuelve 200 con los bloques disponibles y 503 si fallan los cuatro. Una transacción incierta queda **En verificación** y se consulta al core original por referencia antes de reintentar.

La meta es p95 de hasta 500 ms para consultas y hasta 1 segundo para la respuesta inicial de transacciones con referencia y estado. La confirmación de negocio se mide por separado. Las pruebas salen desde Ecuador por Akamai y Apigee a 100 solicitudes por segundo. Dynatrace distingue los tiempos por flujo y dependencia. En Web y App se reportan respuestas completas, parciales y fallidas por separado (12.1).

Recuperación ante desastres

Riesgos y el responsable de la solución clasifican cada subcarga por impacto, tiempo tolerable de interrupción y pérdida aceptable de datos.

Criticidad	Estrategia del caso
Baja	Recuperación bajo demanda con infraestructura como código y respaldos probados. El negocio puede esperar la restauración.
Media	Alta disponibilidad en tres zonas y conmutación dentro de la región. Restauración desde respaldos ante pérdida regional, según el tiempo aceptado.
Alta	Alta disponibilidad multizona en Virginia y recuperación regional en Oregón mediante warm standby.

Estrategia regional con warm standby. Virginia (us-east-1) atiende la producción. Oregón (us-west-2) mantiene Apigee, las subcargas críticas y sus dependencias a capacidad reducida, con estado replicado. Los microservicios críticos sin estado mantienen dos réplicas listas en zonas distintas en Oregón. El caso supone menor latencia desde Ecuador hacia Virginia. Las pruebas miden ambas rutas.

Una transferencia de Personas sirve como flujo crítico de prueba. Se recuperan la subcarga Cuenta Bancaria en EKS Personas, su estado, idempotencia y outbox en Aurora, y sus tópicos en MSK. Se verifican el catálogo, el core vigente y los servicios que intervienen en la operación.

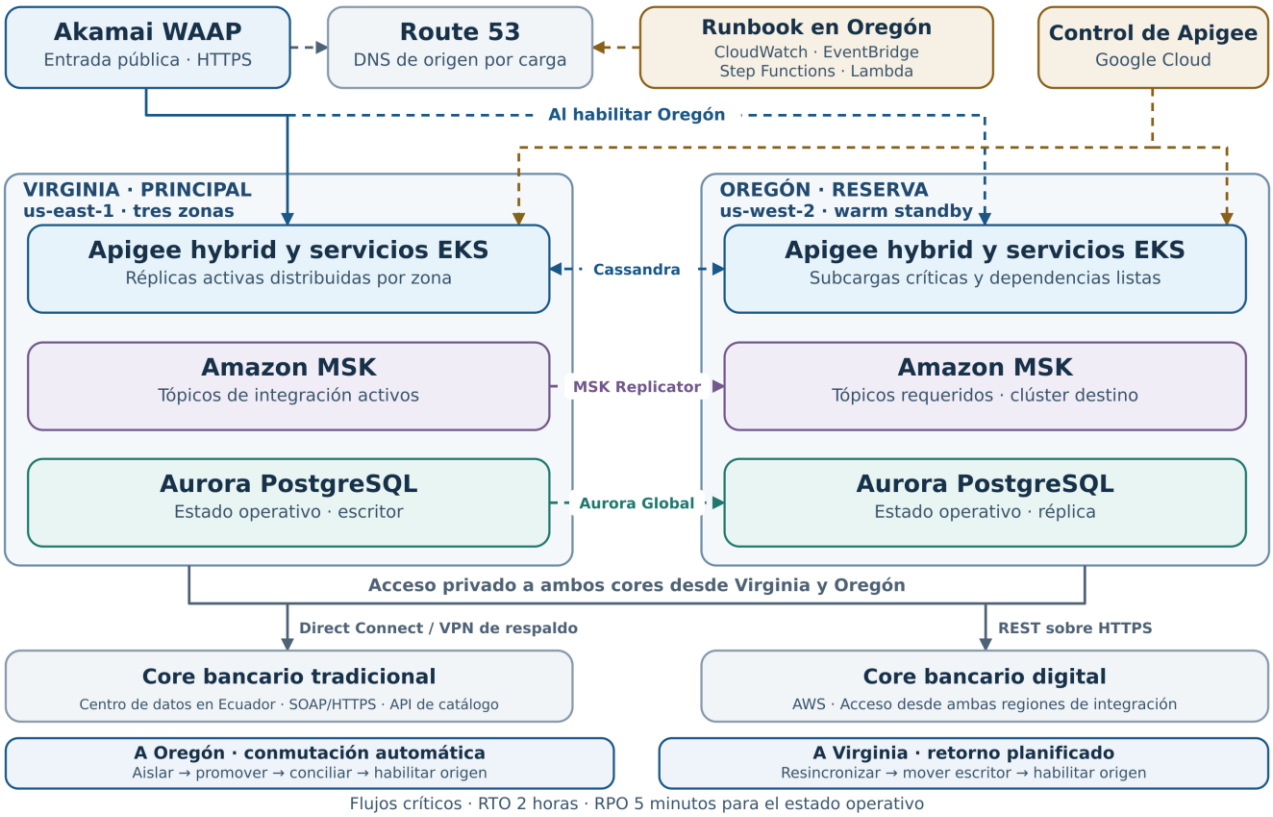


Figura 4 Despliegue y recuperación regional por carga con warm standby

Preparación de la reserva. El pipeline aplica IaC para redes, EKS, rutas privadas y DNS en ambas regiones. Argo CD despliega en Oregón los namespaces críticos y sus dependencias con identidades y secretos regionales. Las subcargas que comparten un escritor se recuperan como una unidad. El ensayo verifica en ambas regiones los flujos permitidos y bloqueados por NetworkPolicy.

Estado y dependencias por carga. Aurora Global Database replica el estado operativo, MSK Replicator copia los tópicos requeridos y Cassandra replica el estado del runtime de Apigee entre regiones. Se conservan respaldos probados. El runbook valida desde ambas regiones las dependencias de cada flujo. El caso supone que el endpoint del core digital se recupera a tiempo para cumplir el RTO del flujo. Cada core mantiene su propia recuperación de datos contables.

Disparo del runbook. EventBridge programa una Lambda en Oregón para probar cada minuto el origen de Virginia por carga. Tras tres fallas consecutivas, la alarma de CloudWatch activa mediante EventBridge el flujo DR-Integración en Step Functions Standard. El runbook confirma la falla y registra el incidente y cada paso.

Control del origen y de las escrituras. Route 53 resuelve para Akamai el origen de cada carga según las alarmas de salud. El runbook guarda la región habilitada o la pausa en Parameter Store de Oregón. Lambda publica la salud de los orígenes en CloudWatch según ese estado y las sondas. Si ambos orígenes quedan indisponibles, las escrituras siguen en pausa y el canal informa la indisponibilidad. El banco controla los permisos de escritura por región en los destinos mediante una API accesible desde ambas regiones.

Conmutación a Oregón

1. Aislar Virginia. El runbook pausa el origen y revoca el permiso de escritura de Virginia. Antes de promover Aurora o activar consumidores en Oregón, comprueba que los destinos rechazan las escrituras de Virginia, incluidas las conexiones abiertas. Si el bloqueo no se confirma, mantiene la pausa y alerta a Operación.

2. Promover y conciliar. Si la pérdida estimada supera cinco minutos o el punto recuperable no puede verificarse, el runbook mantiene la pausa y alerta a Operación. Con el RPO verificado, promueve Aurora con FailoverGlobalCluster y valida Cassandra, los tópicos requeridos y los puntos de consumo de MSK. Transacciones concilia por referencia con las reglas de 7.2, incluso si falta el registro en Aurora.

3. Escalar y habilitar. Argo CD aplica el perfil activo de Oregón. Con las réplicas listas y las identidades habilitadas, el runbook prueba una consulta y un comando sin movimiento contable. En una ruta de prueba verifica HTTPS autenticado entre Akamai y Apigee, mTLS para B2B y el rechazo de acceso directo al origen. Tras superar las pruebas, habilita el origen y confirma el tráfico por Akamai. Apigee informa indisponibilidad para las subcargas fuera de contingencia.

Retorno a Virginia

1. Preparar y resincronizar. Operación inicia el retorno en una ventana de cambio. IaC y Argo CD reponen y escalan Virginia. Mientras Oregón atiende, el runbook comprueba la réplica de Aurora, replica los tópicos requeridos hacia Virginia y valida Apigee y las conexiones a los cores.

2. Mover el escritor. El runbook pausa comandos nuevos en Oregón, concilia las operaciones en curso, detiene consumidores de comandos y revoca los permisos de escritura de Oregón en los destinos. Si no confirma el bloqueo, mantiene la pausa y alerta a Operación. Con los datos sincronizados, ejecuta SwitchoverGlobalCluster y comprueba el escritor en Virginia y el punto de consumo.

3. Habilitar Virginia y rearmar la reserva. El runbook habilita las identidades de Virginia y prueba el flujo de control. Cambia el estado para que Route 53 devuelva el origen principal, confirma el tráfico por Akamai y restablece la reserva y la replicación a Oregón. Si falla una comprobación tras mover el escritor, mantiene la pausa y alerta a Operación.

Escrituras por cuenta durante la conmutación. Cada flujo se habilita con sus dependencias disponibles. Cuenta Bancaria usa el catálogo durante la coexistencia o la ruta fija al cerrar la migración (7.1). Exige ruta Activa para escribir. Los grupos en corte mantienen Escrituras pausadas hasta confirmar el core y conciliar (11). Si solo falla el catálogo, la posición consolidada muestra los bloques disponibles del core digital.

Objetivos y evidencia. El tiempo objetivo de recuperación (RTO) es de 2 horas para flujos críticos. El punto objetivo de recuperación (RPO) es de 5 minutos para su estado operativo. Como supuesto de prueba, 20 de las 100 solicitudes por segundo son transferencias de Personas. Oregón debe sostener esas 20 solicitudes por segundo. El ensayo cubre pérdida de zona, caída regional durante un corte y retorno. Registra carga, p95, tiempo de conmutación por Akamai, RTO desde la interrupción y RPO según el estado recuperado. Comprueba la pausa por cuenta y que reenviar la misma referencia produce un solo movimiento.

7. Coexistencia e integración multicore

Autoridad de datos y enrutamiento

El core vigente de cada cuenta es la autoridad sobre sus saldos, movimientos y estado. El tradicional atiende las cuentas pendientes de migrar. El digital atiende las migradas, las altas habilitadas, Tarjeta de Crédito, Seguros e Inversiones.

El core tradicional aloja el catálogo temporal de Cuenta Bancaria. En la Figura 3B, la Process API resuelve la ruta con el conector SOAP del catálogo y la entrega a Corporate Current Account, que invoca el conector local de cuentas.

Campo	Uso	Ejemplo
Producto	Tipo de cuenta bancaria.	Cuenta corriente
ID de cuenta	Identificador de la cuenta en el canal y la plataforma.	CC-1045
Core vigente	Core vigente de la cuenta que devuelve el catálogo.	Tradicional
ID en el core	Identificador para el conector si difiere del ID de la cuenta.	T-73219
Grupo de migración	Agrupa cuentas que cambian de core en el mismo corte.	Empresas-02
Estado de la ruta	**Activa** permite nuevas escrituras. **Escrituras pausadas** las bloquea.	Activa

Durante la coexistencia, el flujo de apertura registra en el catálogo la ruta al digital y el ID de la cuenta antes de habilitarla. Migración actualiza las rutas del corte. La ruta fija se habilita tras comprobar que el digital reconoce el ID del canal, registra las altas y permite verificar por cuenta los estados Activa y Escrituras pausadas (11.1).

Argo CD despliega los conectores System API en Java/Spring Boot con identidad y pool por namespace (4.1). Operaciones Multiproducto solo consulta. Transacciones escribe con ruta Activa, en el core vigente y con la identidad autorizada de la región habilitada.

Con la ruta Escrituras pausadas, el core vigente atiende consultas (11). La Figura 2 ubica ambos cores. En la Figura 3B, la cuenta ya migró y los otros tres productos tienen ruta fija al digital. Una falla del catálogo afecta solo el bloque de cuentas (6.2).

Consistencia y conciliación

Transacciones deriva la referencia del ID del solicitante y la clave de idempotencia. Antes de enviar, guarda clave, referencia y destino del paso en Aurora. Tras conmutar, consulta la referencia en el destino original si lo identifica, aun si falta el registro. Si el comando pudo aplicarse y persiste la duda, devuelve 202 En verificación con la referencia y Operación concilia. El rechazo por falta de ruta o core indisponible aplica a comandos sin enviar.

Cada cinco minutos, Transacciones coteja monto, moneda y estado por referencia. Consulta el movimiento en el core original y el envío en Pagos si su contrato lo permite. Solo reintenta ese paso con la misma referencia si el destino confirma un fallo transitorio sin aplicación y admite el reenvío.

Transacciones guarda el estado y su evento en una sola transacción de Aurora. El publicador del outbox lo envía a MSK. El idEvento se deriva de la operación y la versión del cambio y se conserva al reconstruir o reprocesar. Si la versión queda incierta, Operación concilia antes de publicar. La prueba de 12.2 verifica una sola evaluación en Riesgos.

8. Identidad y control de acceso

Identidades y autenticación

Onboarding coteja la identidad con el Registro Civil. Usa HTTPS y credenciales técnicas separadas para Registro Civil y Facephi, según sus contratos, guardadas en Secrets Manager. Si aplica la biometría (5.2), Facephi compara la foto de la cédula con una selfie con prueba de vida. El cliente puede seguir la vía documental. Con su identidad técnica, Onboarding consulta solo los datos de alta en CDP para detectar registros previos o diferencias y registra en Consentimientos la aceptación aplicable. En Empresas, el banco verifica las facultades del representante. Se auditan resultado y referencia.

Web y App usan OpenID Connect con Authorization Code y PKCE en Okta, con registro por canal y ambiente. El ingreso usa un identificador distinto de la cédula y dos factores. La App verifica el dispositivo y el número autorizados. Okta emite un access token JWT de corta vigencia, que el canal envía a Apigee como Bearer. Las operaciones de 5.1 exigen un factor de un solo uso vinculado a la operación.

El banco mantiene una sesión activa por usuario entre Web y App y asocia cada token con la sesión que lo originó, incluida la renovación. Un nuevo ingreso cierra la anterior. La sesión caduca por inactividad y exige autenticarse de nuevo. El canal informa el último acceso y notifica el nuevo.

En Open Finance, el banco registra un cliente y un certificado por tercero. El titular autoriza cuentas, datos y vigencia en el portal. Consentimientos guarda esa autorización. El tercero canjea el código con PKCE y mTLS. Antes de publicar, IAM comprueba que Okta emite tokens ligados al certificado y que el proxy rechaza huellas ausentes o distintas (5.1).

Para Servicios de Pago, el banco registra un cliente técnico y un certificado por tercero. La consulta de estado usa mTLS en Akamai y un token OAuth 2.0 Client Credentials (5.1 y 9.1).

El personal de TI ingresa con Entra ID y MFA. Para EKS asume un rol IAM federado. Una access entry vincula el rol al grupo de Kubernetes y RBAC limita el acceso al namespace asignado. Soporte consulta trazas en Dynatrace y pods en EKS con permisos de lectura. PAM gestiona el privilegio temporal aprobado y audita la sesión. Argo CD despliega las correcciones aprobadas con identidad propia por ambiente.

Autorización y control de acceso

Apigee valida firma, emisor, audiencia, vigencia y alcance del access token. Para Web y App verifica su vínculo con la sesión activa registrada por el banco, también en Oregón. Si no puede comprobar la sesión, deniega el acceso.

La Process API valida el token recibido por los enlaces protegidos y autoriza el recurso. En Empresas comprueba la facultad vigente por empresa, producto y operación en el registro del banco. La autorización de un solo uso se vincula a la referencia, cuenta de destino, monto y moneda. La Process API coteja esos datos y su vigencia, y la consume al admitir el comando. En Open Finance, Apigee coteja la huella y la Process API comprueba el consentimiento en cada solicitud (5.1). En Pagos B2B, Apigee coteja el cliente del token con el registrado para el certificado validado por Akamai. La Process API verifica que la referencia pertenezca a ese tercero.

Cada servicio usa su ServiceAccount. Istio aplica mTLS estricto y AuthorizationPolicy por identidad. EKS Pod Identity entrega credenciales temporales de AWS. En MSK, el publicador escribe en sus tópicos con IAM. El adaptador de Riesgos consume con su propio rol IAM por tópico y grupo y entrega a Riesgos por REST con una identidad técnica. Los accesos REST de Pagos, Riesgos y Fraude usan Client Credentials cuando el destino lo admite. Aurora limita el acceso por usuario y esquema. IAM restringe llaves y secretos por servicio.

Los conectores usan credenciales exclusivas por subcarga y destino. Operaciones Multiproducto usa identidad de lectura. El flujo de apertura y Migración actualizan las rutas a su cargo. Transacciones escribe en el core vigente con ruta Activa y la credencial de la región habilitada. En la API de control, el runbook usa una identidad técnica limitada a habilitar o revocar ese permiso por carga.

Auditoría. Se registra actor, operación, recurso, resultado e ID de correlación. El conector vincula ese ID con la referencia del core. Los registros de seguridad se envían al SIEM (5.1).

Evidencia en Tabla 7.

9. APIs internas, Open Finance y mensajería de eventos

APIs internas y externas

Contratos por consumidor. Apigee publica Experience APIs para Personas y Empresas y APIs B2B separadas para Open Finance y Servicios de Pago. El contrato de Open Finance delimita las operaciones, los campos y las cuotas por tercero. El acceso sigue la sección 8.

La plataforma de pagos consulta por referencia el estado registrado por Transacciones en Servicios de Pago de Integración Externos. Apigee coteja el cliente del token con el registrado para el certificado validado por Akamai (8.2). La Process API comprueba que la referencia pertenezca a ese tercero. Transacciones usa el conector a Pagos para el envío.

Contratos de dominio. La Process API coordina el caso. Las APIs de dominio aplican las BIAN Semantic APIs 14.0 en los Service Domains que correspondan. En la Figura 3B, la posición consolidada de empresa ilustra una composición reutilizable en otras consultas. Las System APIs adaptan los contratos REST o SOAP de los destinos.

gRPC con Protobuf se evalúa para llamadas síncronas de baja latencia dentro de una subcarga. Se adopta si mejora el tiempo de punta a punta en las pruebas.

Versionado y errores. OpenAPI 3.2.1 es el contrato maestro. Los cambios compatibles conservan la versión. Los incompatibles abren una versión mayor y ambas conviven durante la transición. Por ejemplo, v1 admite fechaCorte opcional si permite campos adicionales. Retirar saldoDisponible obligatorio requiere v2. Apigee devuelve X-Correlation-ID en respuestas de éxito y error. Los errores usan Problem Details (RFC 9457) con el mismo ID. Si el estado Escrituras pausadas impide enviar un comando al core, la API devuelve 503 con el motivo de la pausa. Ante un pago con resultado incierto, el 202 devuelve la referencia de operación, el estado En verificación y la ruta de consulta de la Tabla 5.

Validación en CI. Un agente de IA compara OpenAPI y AsyncAPI aprobados con el código, la configuración y los archivos .proto, y reporta archivo, línea y regla. CI ejecuta el servicio y contrasta respuestas HTTP y el tópico, clave, cabeceras y contenido del evento con los contratos maestros. Bloquea la publicación ante incumplimientos reproducibles. En proxies con OASValidation, CI deriva las reglas compatibles a OpenAPI 3.0. Para operaciones que reciben JSON, el proxy exige application/json y activa la validación del cuerpo. Las pruebas comprueban Problem Details y X-Correlation-ID en los errores del proxy.

Eventos y reglas de entrega

Publicación y orden. Transacciones registra estado y evento en la misma transacción de Aurora. El publicador lee el outbox y publica en el MSK de su carga en orden de versión, con idOperacion como clave. Si falla la publicación, el evento queda pendiente. Cada adaptador de Riesgos consume del MSK de su carga y entrega por REST (8.2 y Tabla 6).

Esquema y evolución. AsyncAPI 3.1.0 documenta el tópico, el mensaje y traceparent, una cabecera opcional de texto que el publicador envía si existe contexto de traza. CI compila el .proto, lo incorpora al contrato como texto y verifica compatibilidad. Kafka usa Protobuf proto3. Se reservan los números de campos retirados. Los cambios incompatibles usan una nueva versión de tópico y se migran los consumidores.

Entrega y recuperación. Los eventos disponibles en el MSK activo se procesan al menos una vez. El adaptador envía idEvento en Idempotency-Key al entregar por REST. Riesgos guarda clave y evaluación en una transacción y devuelve el resultado registrado ante duplicados. El adaptador reintenta fallas transitorias hasta tres veces con espera creciente. Los fallos permanentes y los que agotan los reintentos pasan a la DLQ. El adaptador confirma el offset tras procesar o recibir el acuse de la DLQ. Al reprocesar, Operación conserva idEvento, idOperacion y versionEstado. Riesgos compara con la última versión aplicada de la operación y registra el descarte de eventos superados. Dynatrace alerta por cantidad o antigüedad de pendientes de publicación. En flujos críticos alerta desde el primer mensaje en DLQ. La réplica regional es asíncrona. Tras conmutar, Transacciones concilia los pendientes y reconstruye eventos recuperables desde el estado confirmado, con el mismo identificador y versión (6.2 y 7.2).

Evidencia en Tabla 5 y Tabla 6.

10. Gobierno de APIs y microservicios

Responsabilidades y catálogo

El gobierno es federado. El dueño de dominio responde por la capacidad de negocio, sus contratos y la coordinación con los consumidores. También aprueba los cambios compatibles. El responsable de la subcarga aprueba la promoción a producción y opera sus servicios y conectores. Arquitectura de Integración define las reglas comunes y revisa las nuevas capacidades, los cambios incompatibles y las excepciones. Seguridad da el visto bueno a las APIs B2B nuevas y a los cambios en los datos compartidos. La publicación requiere ese aval y la evidencia de las pruebas de identidad aplicables (5 y 8). Plataforma mantiene las plantillas de CI/CD y la integración con el CMDB.

El CMDB (base de datos de gestión de la configuración) es el inventario oficial. Git versiona las fichas, contratos y manifiestos. El pipeline registra cada activo por identificador y versión, con sus despliegues por ambiente, región, clúster y namespace, según corresponda. La ficha vincula la capacidad con su responsable, consumidores, contratos y dependencias. En Apigee registra la organización, el ambiente, el API Product, sus proxies y el namespace común de destino. También identifica los servicios y destinos de los conectores en EKS, y los tópicos de MSK con sus productores y consumidores.

El equipo busca en el CMDB por capacidad o Service Domain antes de crear una API o un servicio. Para BIAN 14.0, la ficha registra Business Area, Business Domain, Service Domain, operaciones y, cuando BIAN lo publica, Business Scenario. CI coteja las etiquetas BIAN aplicables al despliegue (3.5) con la ficha. Pólizas de Seguros se registra como contrato propio. Corporate Card Service vincula la consulta de saldo utilizado y cupo disponible (Figura 3B) con su conector REST al core digital. Otra subcarga puede reutilizar el contrato y el artefacto en su namespace.

Ciclo de vida y conformidad

Estado	Condición para registrarlo en el CMDB
Diseñado	Se aprueban en Git la capacidad, el responsable y el contrato inicial. CI registra la ficha.
En pruebas	Se confirma el despliegue en pruebas. El registro de promoción enlaza los resultados de seguridad, contratos y observabilidad de las secciones 5, 9 y 12.2.
En producción	Tras la aprobación de la promoción (10.1), el pipeline verifica la revisión activa en Apigee o el despliegue sano en EKS mediante Argo CD. Para eventos verifica el tópico en MSK y el despliegue del productor, y registra la prueba de publicación y consumo (12.2).
En retiro	El dueño comunica la fecha de retiro, identifica a los consumidores afectados y acuerda su migración.
Retirado	Tras confirmar la migración y la ausencia de uso en el período acordado, se retira la versión y se deshabilitan sus rutas o suscripciones. Se revocan sus permisos exclusivos y el CMDB conserva el historial.

Antes de ampliar por namespace, el responsable verifica errores, latencia y réplicas listas (4.2 y 6.1). Si hay una regresión, detiene la ampliación. La reversión de software respeta el core vigente y las pausas de escritura (7). Cada promoción o reversión registra la aprobación, el commit y la ejecución del pipeline.

El CMDB registra el estado por versión y distingue los despliegues activos y de reserva. Plataforma concilia a diario el inventario con Apigee, Argo CD y MSK. Asigna las diferencias al responsable y actualiza la ficha con el estado verificado. Tras conmutar o retornar, registra la región habilitada o la pausa según el runbook (6.2).

La Tabla 3 relaciona capacidad, dominio BIAN y responsable. La ficha del CMDB enlaza el contrato, la versión desplegada y la evidencia de publicación.

11. Migración gradual y transición operativa

La migración gradual abarca exclusivamente Cuenta Bancaria. Tarjeta de Crédito, Seguros e Inversiones se habilitan directamente en el digital. El cambio de core por grupo se gestiona en el **catálogo de enrutamiento de cuentas**, descrito en la sección **7. Coexistencia e integración multicore**. La **ruta** identifica el core vigente, el ID de la cuenta en ese core y su estado. Durante el corte, Migración cambia la ruta a **Escrituras pausadas** y la habilita como **Activa** al cumplir los controles de reapertura de 11.2.

Fases de transición

1. Preparación. Migración agrupa las cuentas por producto y dependencias y revisa con los responsables los canales, conectores y servicios afectados. Se asume que el banco puede exportar y cargar en el digital el estado, los saldos y los movimientos. Antes de la pausa, Migración carga la copia inicial, registra su punto de copia y concilia el lote. Ensaya con datos enmascarados la carga, el corte y el retorno aplicable (11.2). Las pruebas cubren consultas, pagos y, cuando aplique, Fraude y la entrega de eventos a Riesgos. Las copias de producción se cifran y el acceso se registra por lote y se limita a las ventanas autorizadas. Tras conciliar, Migración verifica el borrado según 5.2.

2. Piloto. Se migra un grupo reducido de cuentas de baja actividad de un mismo producto, por ejemplo, cuentas corrientes empresariales. Se verifica que Web y App consulten los saldos en el digital. Cuando aplique al lote, se prueba Open Finance con el mismo ID y consentimiento vigente, y Pagos B2B con la referencia de un pago previo del mismo tercero.

3. Ampliación gradual. Se propone un período inicial de **cuatro semanas, con una ventana semanal**. El tamaño de los grupos aumenta según los resultados. Antes de pasar al siguiente grupo, Operación observa el grupo migrado durante al menos un día hábil y verifica su cierre contable. Los saldos y movimientos deben cuadrar, los eventos críticos deben haberse procesado y las pruebas de latencia deben cumplir los objetivos de la sección 6. El corte debe registrar cero operaciones duplicadas. Se repiten las pruebas del piloto aplicables al lote. Si algún control falla, se corrige y se reprograma la siguiente ventana.

4. Cierre. Con el último grupo conciliado, Operación prueba la consulta, el alta y la escritura por la ruta fija al digital. Verifica el ID del canal, la pausa por cuenta y el permiso regional (7.1). El responsable de la subcarga promueve la ruta. El catálogo y las integraciones temporales se retiran al confirmar el cese de uso y la ausencia de pendientes o dependencias activas del tradicional. La promoción y el retiro siguen 10.2.

Reversión y control del riesgo operativo

El **dueño del dominio**, con el visto bueno de Operación, decide si el grupo avanza, se detiene o revierte. Migración actualiza el core, los identificadores y el estado de la ruta con su identidad autorizada. Registra la hora, las cuentas afectadas, el resultado de la conciliación y la decisión.

Para el ejercicio se fija una ventana de **30 minutos** desde la pausa de nuevas escrituras. El dueño del dominio decide a más tardar en el **minuto 20**. Si queda pendiente el bloqueo o la conciliación, detiene el corte. Los 10 minutos restantes se reservan para retornar antes de la primera escritura de negocio en el digital. El ensayo valida el margen y define el tamaño del lote.

Cambio de core por grupo

1. Migración cambia el **Estado de la ruta** de las cuentas del lote a **Escrituras pausadas**. Los comandos nuevos se rechazan según 9.1. El core vigente atiende las consultas. Operación detiene los procesos programados y consulta los envíos inciertos por referencia en el core original (7.2). Si un pendiente puede cambiar el saldo, detiene el cambio de core y mantiene la pausa. La idempotencia queda en Aurora y el reproceso conserva el idEvento (9.2). Antes de la carga final, Operación verifica el rechazo de escrituras de negocio del lote en ambos cores, la continuidad de las demás cuentas y el permiso para la carga técnica.

2. Migración carga solo los cambios posteriores al punto de copia. Operación verifica el estado y las restricciones de cada cuenta, como un bloqueo de débito. Compara saldos por moneda y movimientos por referencia, monto y estado. Si quedan diferencias al llegar al plazo de decisión, se detiene el corte.

3. Con la conciliación aprobada, Migración registra el **digital como core vigente** y sus identificadores. La ruta conserva el estado Escrituras pausadas hasta la reapertura.

Reapertura de operaciones. Con la ruta en pausa, Operación comprueba el destino mediante una consulta de solo lectura, confirma que el otro core siga bloqueado y verifica que el permiso de escritura del lote esté habilitado en el core vigente para la región autorizada (6.2 y 8.2). Con su visto bueno, Migración marca la ruta **Activa**. Operación reanuda los procesos y verifica que la primera escritura de negocio se registre en el core vigente.

Reversión

Antes de la primera escritura de negocio en el digital. Operación confirma que el digital esté bloqueado y que el lote tenga cero escrituras de negocio nuevas o pendientes allí. Migración restablece el tradicional y sus identificadores en el catálogo y aplica la reapertura.

Después de la primera escritura de negocio en el digital. Migración vuelve a **Escrituras pausadas** y Operación detiene los procesos. Tras conciliar los pendientes según 7.2 y confirmar el bloqueo del digital, el retorno exige una carga inversa ensayada en el tradicional. Se incorporan los movimientos como datos y se cotejan por referencia junto con saldos y estados. Con la conciliación aprobada, Migración restablece el tradicional y sus identificadores. Si el retorno resulta inviable, el digital conserva la autoridad y la pausa hasta corregir y validar. En ambos casos se aplica la reapertura para volver a **Activa**.

Contingencia durante el corte. Ante una conmutación o un retorno regional en cualquier paso del corte, Operación suspende el lote y Migración mantiene las cuentas en **Escrituras pausadas**. El dueño del dominio decide con Operación si retoma o revierte tras verificar el core vigente, la región autorizada y la conciliación de pendientes (6.2 y 7.2).

Evidencia en Tabla 4.

12. Observabilidad y trazabilidad

Telemetría y correlación

Dynatrace centraliza las métricas, los registros y las trazas de la plataforma. En cada clúster EKS, **Dynatrace Operator** configura OneAgent en modo de observabilidad de aplicaciones para instrumentar los servicios Spring Boot que se ejecutan sobre una **JVM compatible**. ActiveGate consulta la API de Kubernetes para observar pods, réplicas y eventos. El módulo de logs de Kubernetes recoge los registros de los contenedores. La cobertura se comprueba con pruebas desde el canal hasta el sistema de destino y, cuando interviene mensajería, hasta el consumidor del evento.

De dónde llega la telemetría. Akamai envía los registros operativos seleccionados mediante DataStream 2. Apigee hybrid registra el proxy, el código de respuesta, la duración y los identificadores de la petición mediante MessageLogging en Cloud Logging, desde donde se reenvían a Dynatrace. La integración con AWS incorpora métricas de CloudWatch y reenvía los grupos seleccionados de CloudWatch Logs mediante Amazon Data Firehose. Los registros de auditoría y las alertas de seguridad se envían al SIEM por las fuentes identificadas en 5.1, con la misma correlación cuando esté disponible.

Medición desde Web y App. Dynatrace Real User Monitoring (RUM) mide la duración desde el envío hasta recibir la respuesta. El p95 se calcula por canal y tipo de operación. Se reportan por separado las respuestas completas, parciales y fallidas. El 503 previsto durante el corte se identifica por el motivo de la pausa y la ventana del lote (9.1 y 11.2). En transacciones se mide hasta la respuesta inicial con referencia y estado. La confirmación de negocio se mide aparte.

Seguimiento de una petición. Akamai registra su identificador de borde. Operación lo usa para buscar bloqueos HTTP previos al gateway. Para las solicitudes admitidas, Akamai envía ese identificador a Apigee por el enlace autenticado. El gateway asigna un **ID de correlación**, lo vincula con el de Akamai y lo devuelve al canal en X-Correlation-ID. Las APIs y los conectores registran el mismo ID. Los saltos instrumentados propagan traceparent. El conector registra destino, duración y resultado. En transacciones vincula el core registrado y la referencia enviada con el ID de correlación y el idOperacion, incluso si vence la espera. Añade la referencia devuelta si está disponible. Se prueban por separado un bloqueo en Akamai y un error en Apigee. La consulta autorizada de Pagos B2B del piloto (11.1) comprueba el seguimiento desde Akamai hasta la lectura del estado en Aurora.

Seguimiento de un evento. Transacciones asocia el ID de correlación y el contexto de traza con la referencia de operación en Aurora. La bandeja de salida conserva esa relación y el publicador envía traceparent en la cabecera del mensaje en MSK cuando hay contexto de traza. El consumidor vincula su procesamiento con el del productor. La referencia idOperacion permite seguir una transacción aunque una consulta posterior tenga otro ID de petición. El idEvento permite localizar sus reintentos y su envío a la DLQ.

Los registros incluyen fecha, servicio, región, resultado e identificadores técnicos. En registros, RUM y trazas se excluyen credenciales, tokens y cuerpos de mensajes y se enmascaran parámetros y datos sensibles desde la captura (5). El acceso de soporte sigue los permisos de la sección 8.

Alertas y diagnóstico

En la **implementación de cada funcionalidad**, el equipo instrumenta el flujo, configura su **vista en Dynatrace** y prueba las **alertas automáticas**. La vista reúne señales de negocio, infraestructura y seguridad. Se filtra por carga, namespace, versión y región según el componente. Cada alerta registra condición, período de evaluación, responsable y acción inicial.

Flujo o componente	Qué muestra la vista	Cuándo se alerta y quién atiende
Web, App, Open Finance, Pagos B2B, Akamai y Apigee	Disponibilidad, errores y latencia por canal. Respuestas completas, parciales, fallidas y rechazos por pausa.	Operación atiende indisponibilidad y p95 fuera de objetivo. En Web y App, hasta 500 ms en consultas y 1 s hasta la respuesta inicial de transacciones (6.1).
EKS, Istio y conectores	Réplicas listas, pods pendientes, saturación y tiempos de los cores, Pagos, Riesgos, Fraude y demás dependencias.	Plataforma atiende fallas de comunicación, réplicas bajo el mínimo, pods pendientes y saturación con el HPA al máximo. El dueño del destino revisa fallas de su servicio.
Transacciones, Aurora y MSK	Operaciones confirmadas, rechazadas y En verificación. Volumen y antigüedad del outbox, rezago del consumidor y DLQ.	Operación y el dueño del flujo atienden alertas por pendientes vencidos, volumen o antigüedad del outbox y primer ingreso a DLQ en flujos críticos (9.2).
Conectividad y recuperación	Direct Connect y VPN. Región o pausa por carga, motivo y rezago. Resultado del runbook y tiempo y punto de recuperación en el ensayo.	Plataforma atiende fallas de enlace o del runbook. Operación revisa la pausa por pérdida estimada mayor a 5 min o punto recuperable incierto (6.2).
Seguridad y accesos	Bloqueos de Akamai, fallas de autenticación, denegaciones de permisos y errores de mTLS.	Operación recibe alertas por aumentos de errores que afectan el servicio. El SOC investiga los eventos de seguridad en Falcon Next-Gen SIEM, según la sección 5.

Prueba de posición consolidada. Se simulan por separado la falla de una API del digital y la del catálogo, que solo afecta a cuentas durante la coexistencia. Se espera 200 parcial si queda algún bloque y 503 si fallan los cuatro. Con el digital caído, una cuenta pendiente mantiene su bloque si responden el catálogo y el tradicional. Las trazas se correlacionan con X-Correlation-ID.

Prueba de aceptación. En la Figura 5A se retrasa la respuesta del core tras aplicar OP-1001. Se verifica el 202 En verificación con X-Correlation-ID e idOperacion. Transacciones concilia por referencia en el core registrado y guarda la confirmación con el evento. La consulta de estado muestra el paso a Confirmada. En la Figura 5B se fuerza un fallo de entrega a Riesgos hasta agotar los reintentos y se comprueban la DLQ y la alerta a Operación. Tras el reproceso exitoso, se reenvía el mismo idEvento y luego una versión anterior aún no procesada de la misma operación. Se verifica una sola evaluación en Riesgos y el descarte de la versión anterior.

Evidencia de promoción. Antes de liberar, el registro de promoción (10.2) incluye la respuesta, la traza o los registros correlacionados, la alerta a Operación y las señales del despliegue evaluado. Se verifican los filtros de datos sensibles y los identificadores técnicos en registros, RUM y trazas.

Secuencia de la prueba en la Figura 5.

13. Artefactos de arquitectura

Matriz de dominios y correspondencia con BIAN

La matriz vincula las capacidades con BIAN cuando corresponde e identifica contratos propios, como el de pólizas de la Figura 3B. El permiso de acceso de terceros se alinea con Customer Access Entitlement. La Process API de Open Finance verifica el consentimiento (8.2).

Tabla 3 Capacidades y dominios de servicio

Capacidad del caso	Dominio	Sistema o servicio	Responsable	API o evento
Cuentas corrientes de personas	Current Account	Core vigente según fase (§7.1)	Equipo de Cuentas	Consulta de saldo y movimientos
Cuentas corrientes empresariales	Corporate Current Account	Core vigente según fase (digital en la Figura 3B)	Equipo de Cuentas	Consulta de cuentas y saldos disponibles
Cuentas de ahorro	Savings Account	Core vigente según fase (§7.1)	Equipo de Cuentas	Consulta de saldo y movimientos
Tarjetas corporativas	Corporate Card Service	Core digital por REST	Equipo de Tarjetas	Tarjetas vinculadas. Saldo utilizado y cupo disponible de la cuenta maestra.
Tenencias de inversión	Investment Account	Core digital por REST	Equipo de Inversiones	Consulta de instrumentos y valoración al último corte
Pólizas empresariales	Pólizas de Seguros (propio)	Core digital por REST	Equipo de Seguros	Consulta de vigencia y cobertura
Orquestación de pagos	Payment Orchestration	Process API de Transacciones	Equipo de Pagos	Reserva y confirmación. Envío a la Plataforma de Pagos con contrato REST propio.
Permisos de terceros	Customer Access Entitlement	Open Finance	Equipo de Open Finance	Consulta externa autorizada
Evaluación de riesgo transaccional	Contrato propio	Gestión de Riesgos	Equipo de Riesgos	Evaluación por REST a partir de un evento de transacción.
Evaluación de fraude	Fraud Evaluation	Prevención de Fraudes	Equipo de Fraude	API REST de evaluación

Matriz de sistemas de registro

Tabla 4 Autoridad sobre datos y réplicas

Dato o entidad	Fase	Sistema de registro	Autoridad de escritura	Réplica y conciliación
Cuenta, estado, saldo y movimientos	Sin migrar	Core tradicional	Core tradicional	Carga inicial al digital para validar la copia.
Cuenta, estado, saldo y movimientos	Corte o reversión	Core vigente según el catálogo	Escrituras de negocio en pausa. Carga técnica autorizada.	Cotejo de estado, saldos por moneda y movimientos por referencia.
Cuenta, estado, saldo y movimientos	Migrada o alta habilitada	Core digital	Core digital	Conciliación al cierre y verificación de operaciones por referencia.
Ruta de cuenta	Durante la coexistencia	Catálogo en el core tradicional	Apertura registra altas. Migración actualiza el lote.	Verificar core vigente, ID en el core y estado. Retiro según 11.1.
Tarjetas, pólizas y posiciones de inversión	Desde el alta	Core digital	Core digital	Conciliación en el core digital según el producto.
Estado de transacción, clave de idempotencia y outbox	Todas	Aurora de la carga	Transacciones, en su esquema	Réplica regional para subcargas críticas. Pendientes conciliados por referencia en el core registrado.
Consentimiento	Todas	Consentimientos	Consentimientos	En cada consulta de Open Finance se validan titular, tercero, cuenta, alcance, vigencia y revocación.

Ejemplos de contratos de APIs

Tabla 5 Inventario de ejemplos de API

Exposición	Operación y versión	Consumidor	Acceso	Petición, respuesta y errores
Canal propio	GET /v1/empresas/{idEmpresa}/posicion	Web Empresas	Banca digital, §8	EMP-01 devuelve 200 con los bloques disponibles y marca los indisponibles. Indica fecha de corte y moneda cuando aplica. Devuelve 503 si fallan los cuatro bloques.
Interna BIAN	GET · v1 Corporate Current Account Retrieve	Process API de posición consolidada	Identidad de carga, §8	CCA-1045 devuelve 200 con el Control Record de cuenta corriente. La API de dominio consulta al conector local.
Open Finance	GET /open-finance/v1/cuentas/{idCuenta}/saldos	Tercero autorizado	Por cuenta, §8	OF-1045 devuelve 200 con moneda USD y saldoDisponible como texto, por ejemplo 125.00. Consentimiento revocado devuelve 403.
Canal propio	POST /v1/pagos	Web o App	Banca digital, §8	Cuenta de origen, referencia de pago, monto, moneda y clave de idempotencia. 202 con OP-1001, estado En verificación, ruta de consulta de la fila siguiente y X-Correlation-ID. 409 si cambia la petición con la misma clave. 503 con motivo de pausa en Problem Details si se bloquea el envío al core.
Canal propio	GET /v1/pagos/{referencia}/estado	Web o App	Banca digital y permiso sobre la operación (§8.2)	200 con el estado de OP-1001 en Aurora. En el ejemplo pasa de En verificación a Confirmada tras la conciliación.
B2B Servicios de Pago	GET /b2b/pagos/v1/operaciones/{referencia}/estado	Plataforma de servicios de pago	mTLS y OAuth 2.0 Client Credentials del mismo tercero (§8.2)	OP-B2B-01 devuelve 200 con referencia y estado de la operación registrada en la subcarga Servicios de Pago. Devuelve 404 si la referencia no está disponible para ese tercero.

Ejemplo interno BIAN. GET /v1/CorporateCurrentAccount/CCA-1045/Retrieve. El 200 de posición consolidada y el 403 de Open Finance devuelven X-Correlation-ID. El 403 incluye el mismo ID en Problem Details junto con el tipo y el estado.

Ejemplos de eventos

Tabla 6 Contrato de un evento

Evento y versión	Productor	Consumidores	Clave y esquema	Entrega y recuperación
Cambio de estado de transacción, v1	Transacciones registra. El publicador del outbox envía a MSK.	Adaptador de Riesgos de la carga	Clave idOperacion. Protobuf proto3. traceparent opcional. Tópico y datos en el ejemplo.	Hasta 3 reintentos ante falla transitoria. DLQ si es permanente o se agotan. Confirmar offset tras procesar o con acuse de DLQ. Pruebas en 12.2.

Ejemplo de evento. El publicador envía CambioEstadoTransaccion a transacciones.estado.v1 en el MSK de la carga. La DLQ del adaptador es riesgos.transacciones.dlq.v1. El mensaje lleva idOperacion OP-1001, idEvento EV-1001-02, estado CONFIRMADA y versionEstado 2. Incluye monto de 12500 centavos, moneda USD, fecha 2026-11-07T15:00:00Z e ID de correlación COR-1001.

Tabla de controles de seguridad

Tabla 7 Controles y evidencias de seguridad

Control	Riesgo u obligación	Punto de aplicación	Responsable	Evidencia
WAAP, HTTPS/mTLS y JWT	Ataques y acceso indebido	Akamai y Apigee hybrid	Seguridad e IAM	Rechazo de token vencido, certificado inválido y acceso directo al origen.
Autenticación fuerte y sesión	Suplantación en banca Web y App	Canales, Okta, Apigee y Process API	IAM y Canales	Rechazar token vigente de sesión cerrada, ingreso sin MFA y reto repetido o con monto distinto. Verificar dispositivo, inactividad y avisos.
Alta, CDP y consentimiento	Suplantación y uso indebido de biometría	Onboarding, Facephi, Registro Civil, CDP y Consentimientos	Onboarding y Datos	Alta documental, consentimiento, evaluación de impacto y borrado. Rechazo de un acceso ajeno a la finalidad.
Autorización de empresa y producto	Exposición de datos ajenos	Process API de posición consolidada	Dueños de dominio	Rechazar consultas de otra empresa o con facultad revocada, incluso con token vigente.
Open Finance con mTLS y consentimiento	Suplantación o acceso sin consentimiento	Akamai, Apigee, Okta, Process API y Consentimientos	IAM y Open Finance	Emisión de token ligado al certificado. Rechazo con huella falsa, certificado distinto o consentimiento revocado.
Consulta B2B de estado de pago	Acceso a operaciones de otro tercero	Akamai, Apigee y Process API de Servicios de Pago	IAM y Pagos	Rechazar token y certificado de terceros distintos o una referencia ajena.

Control	Riesgo u obligación	Punto de aplicación	Responsable	Evidencia
Istio, NetworkPolicy, RBAC y admisión	Movimiento lateral y escalada	Clústeres y namespaces de EKS	Plataforma	Soporte de NetworkPolicy en IaC. Flujo autorizado y denegación entre subcargas en ambas regiones.
Identidad de servicio y acceso a datos	Uso indebido de recursos	ServiceAccount, IAM, MSK, Aurora y Secrets Manager	Plataforma y Transacciones	Rechazo de tópico, grupo o secreto ajeno. Rechazo de escritura en esquema de Transacciones con otra identidad.
Credencial exclusiva del conector	Permisos excesivos en el core	Conector, Secrets Manager y core	Plataforma y dueño del core	Comprobar rotación. Rechazar escrituras con credencial de consulta o de región inactiva.
MFA y PAM del personal de TI	Privilegios administrativos indebidos	Entra ID, PAM, consolas y EKS	IAM y Plataforma	Verificar lectura del rol federado en el namespace asignado y auditar el privilegio temporal aprobado.
TLS, KMS y cifrado por flujo	Exposición de datos y claves	APIs, almacenes y respaldos	Seguridad y Datos	Inventario de llaves y prueba de acceso autorizado. Si aplica JWE, rechazo de contenido alterado.
SAST, SCA, DAST y admisión	Vulnerabilidades de código e imágenes	Pipeline, pruebas y EKS	DevSecOps	Resultados de análisis, artefacto aprobado y rechazo de imagen no autorizada.
Minimización de tarjetas y PCI DSS	Exposición de datos de tarjeta	Core digital, conector y posición consolidada	Tarjetas y Seguridad	Dato reducido en el contrato y las trazas. Inventario de alcance y prueba de segmentación.
Protección de copias de migración	Exposición de datos durante el corte	Exportación, carga y temporales de cuentas	Migración y dueño del core	Cifrado, acceso por lote y ventana, y evidencia de borrado tras conciliación.
Auditoría y detección	Incidentes sin trazabilidad	SIEM, Dynatrace, CloudTrail, Aurora, Apigee y Process API	SOC y Seguridad	Alerta correlacionada. Verificar en registros, RUM y trazas el enmascarado, los ID técnicos y la exclusión de credenciales, tokens y cuerpos.
Respuesta y notificación de brechas	Aviso fuera del plazo aplicable	SOC, CSIRT interno y procedimiento de brechas	Banco y Delegado	Simulacro con hora de constancia, evaluación, destinatarios, plazos y acuses.

Diagrama de secuencia

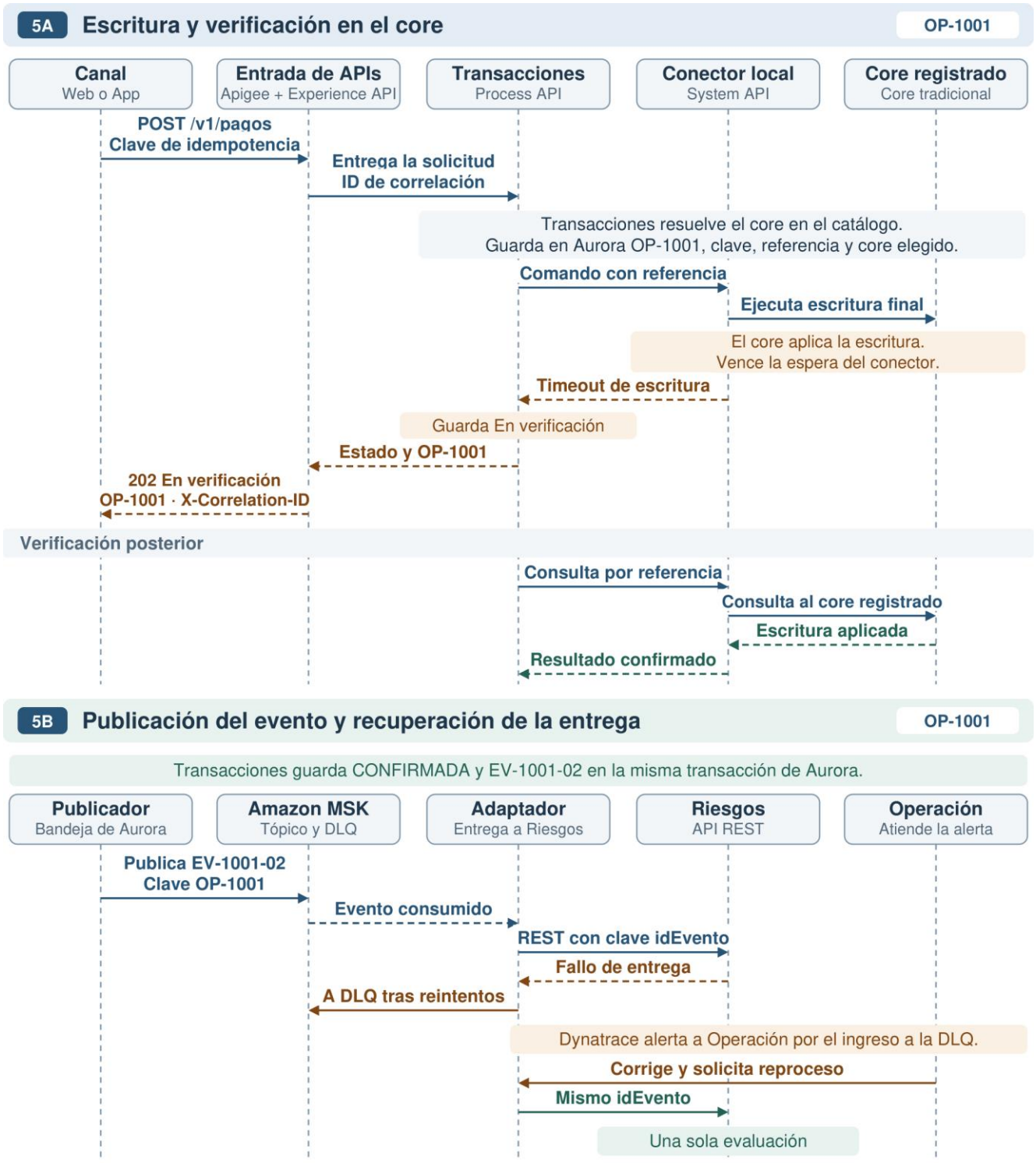


Figura 5 Verificación y trazabilidad de una transacción con resultado incierto

En la Figura 5A, el core tradicional aplica OP-1001 antes del timeout. El canal recibe 202 En verificación y consulta el estado hasta obtener Confirmada. Transacciones verifica por referencia en el core registrado. El caso supone esa consulta en ambos cores. Solo se reintenta con la misma referencia si el destino confirma que el comando quedó sin aplicar por una falla transitoria y admite el reenvío. Si persiste la duda, Operación concilia. La prueba de 5B verifica, tras el reproceso, una sola evaluación ante el mismo idEvento y el descarte de una versión anterior (12.2).

Registro de decisiones de arquitectura

Tabla 8 Decisiones y alternativas

ID y estado	Decisión	Alternativas	Justificación	Consecuencias
ADR 01 Adoptada	Apigee hybrid con API-led	Amazon API Gateway o ESB centralizado	Gobierna la exposición por consumidor y mantiene el runtime junto a los servicios.	Se administran contratos y políticas entre Google Cloud y AWS.
ADR 02 Adoptada	EKS Auto Mode con una base operativa común	EKS con grupos de nodos administrados o ECS	Usa los límites por clúster y namespace definidos en C2 y reduce la gestión de capacidad.	Los runtimes y operadores se despliegan con versiones compatibles.
ADR 04 Adoptada	Kafka en MSK con outbox transaccional	REST encadenado o SNS/SQS	Desacopla consumidores y permite releer cambios de estado por operación.	Se gestionan esquemas, duplicados, reintentos y DLQ.
ADR 05 Adoptada	Saga orquestada para pagos con varios pasos	Saga coreografiada o coordinación síncrona de punta a punta	Un orquestador conserva la referencia y decide cuándo confirmar, compensar o conciliar.	Se persiste el estado de la saga y se verifica el resultado incierto en el sistema original.
ADR 06 Propuesta	Direct Connect principal con VPN IPsec de respaldo	VPN como enlace único o dos enlaces Direct Connect	Concreta el enlace principal y la ruta de continuidad de la Figura 4.	Añade costo de conectividad y pruebas de conmutación y capacidad.
ADR 07 Adoptada	Adoptar el core bancario digital	Continuar con el core tradicional	Mejora Cuenta Bancaria e incorpora Tarjeta de Crédito, Seguros e Inversiones.	Coexistencia durante la migración de cuentas. Los otros tres productos se habilitan en el digital.
ADR 08 Adoptada	Migración de Cuenta Bancaria por lotes	Corte único para todas las cuentas	Limita el impacto del corte. El catálogo temporal identifica el único core escritor por cuenta.	Pausa de escrituras y conciliación por lote. Retiro del catálogo al cierre de la migración.

Matriz de trazabilidad del ejercicio

Tabla 9 Cobertura de los requisitos

ID	Requisito del ejercicio	Sección	Evidencia y comprobación
T01	Arquitectura de alto nivel y BIAN	3 y 13.1	Contexto general (Figura 1), C2, C3 y matriz de dominios
T02	Patrones y tecnologías justificados	4.2–4.3 y 13.7	Patrones por flujo, justificación tecnológica y alternativas en los ADR.
T03	Seguridad, cumplimiento y LOPDP	5 y 13.5	Controles por flujo, registros de tratamiento y simulacro de notificación.
T04	Alta disponibilidad y recuperación	6	Pérdida de zona, conmutación y retorno con carga, p95, RTO, RPO y prueba de reenvío.
T05	Estrategia de integración multicore	7 y 13.2	Catálogo de cuentas, rutas fijas al digital y autoridad por producto.
T06	Identidad y acceso en los sistemas	8 y 13.5	Pruebas de autenticación fuerte, autorización por recurso y acceso B2B.
T07	APIs internas, externas y mensajería	9, 12.2, 13.3 y 13.4	Contratos de canales, Open Finance, Pagos B2B y eventos. Probar la consulta tras el 202, la entrega a Riesgos y el reproceso desde la DLQ.
T08	Gobierno de APIs y microservicios	10	Verificar en la ficha de Corporate Card Service el responsable, el contrato aprobado, la versión desplegada y la evidencia de promoción.
T09	Migración gradual con riesgo acotado	11 y 13.2	Piloto y reversión de Cuenta Bancaria. En el corte, verificar el bloqueo en ambos cores, la conciliación y la primera escritura en el core vigente.
T10	Observabilidad y trazabilidad	12 y 13.6	Seguimiento de OP-1001 hasta la DLQ, alerta, reproceso, evaluación única ante el duplicado y descarte de la versión anterior.
P01	Principios de diseño aplicados	4.1	Decisión y prueba por principio, incluida la degradación si falla el catálogo.